Security & Compliance

Polycarpic — a virtual Single Family Office

Owner: `seceng` agent

Status: Draft v1.1. SecEng confirmations on ARCH v1.3 (OQ-19, OQ-23, OQ-24, OQ-25) are folded in. Every Principal question in this pass (P1–P9, P5b, R-19, R-20) is ruled. Pending: the architect's re-fold (§12.2, A-16 to A-22).

Traces to: PRD v1.3, ARCH v1.3 draft, DECISIONS through 2026-11-07 **Last updated:** 2026-11-07

<details>
<summary>Changelog</summary>

- **v1.1 (2026-11-07).**
  - Nesting, roll-up and cap table: §3.8, C-19 amended, new C-25 and C-27, and new roles `poly_graph` and `poly_stake`.
  - Account deletion in-flow: §4.6 and C-52.
  - The purge delay is removed (OQ-23, R-16).
  - Staging keyring and Plaid Sandbox (C-77).
  - Local-network box posture (C-76).
  - Vercel is now the tertiary target.
  - New risks R-15 to R-21; every §11 row is approved.
  - Principal rulings P1–P9, P5b, R-19 and R-20:
    - MFA for owner and manager;
    - any-range roll-up, with consent disclosure;
    - the hash chain in POLY-M2;
    - the ancestor-invite notice;
    - co-owner approval, with a founding owner;
    - no sign-up switch;
    - local-box TLS, TPM unlock and backups.
- **v1 (2026-09-28).** Reviewed rewrite that supersedes 8963efb.
</details>

CONTENTS

1. Compliance Posture
2. Trust Boundaries
3. Threat Model (STRIDE)
4. Authentication & Authorization
5. Data Classification & Handling
6. Secret Management
7. Controls Catalog
8. CI/CD Security
9. Logging, Monitoring, Detection
10. Incident Response
11. Open Risks (Accepted)
12. Rulings on ARCH Open Questions

1. Compliance Posture

Source of truth is PRD §6 (Non-Functional Requirements) and the Principal's audience decision of 2026-09-27.

Polycarpic is software a person installs and runs for their own household. The Principal will never operate it as a service for others. That is a standing non-goal (PRD §3), not a v1 deferral. Nobody is anybody's "customer", so no formal compliance regime attaches.

That does not lower the bar. The Principal made the PRD §6 security items hard requirements, and this document treats them that way. Every control here answers a threat in §3, not an auditor. The yardstick is **OWASP ASVS 4.0 Level 2**, used as a checklist, not as a certification target.

Regime	In scope?	Why	Target evidence
GLBA Safeguards Rule	No	Applies to financial institutions that serve customers, and a self-hosted personal tool has none. It would likely attach if the hosting non-goal were reversed (R-6).	—
PCI-DSS	No	We never store, process or transmit card numbers. Aggregators expose transactions, not PANs. Adapters must not persist a PAN even if a provider payload carries one (C-34).	C-34 adapter fixture test
GDPR / CCPA	No (voluntary alignment)	Processing by a natural person in a purely personal or household activity falls under the GDPR Art. 2(2)(c) household exemption. CCPA thresholds are never met. We adopt the data-rights practices anyway (PRD §6): export, account deletion and entity purge, all scoped to the immutable ledger.	C-50, C-51, C-52
SOC 2	No	No service organization and no customers.	—
HIPAA	No	No health data by design. Payee strings can still reveal medical providers, which is one reason memo and payee text is Tier 3 (§5).	—
Aggregator terms (Plaid, SimpleFIN)	Yes, per operator	Each self-hoster obtains their own provider keys and accepts that provider's terms. Plaid production access comes with a security questionnaire. The controls here are written so an operator can answer it truthfully.	§6, C-30 to C-35

Regime	In scope?	Why	Target evidence
Tax record retention (IRS guidance, 3–7 years)	Advisory	Not a regime we enforce. The purge flow must warn the owner about it (PRD §5).	C-50 warning copy

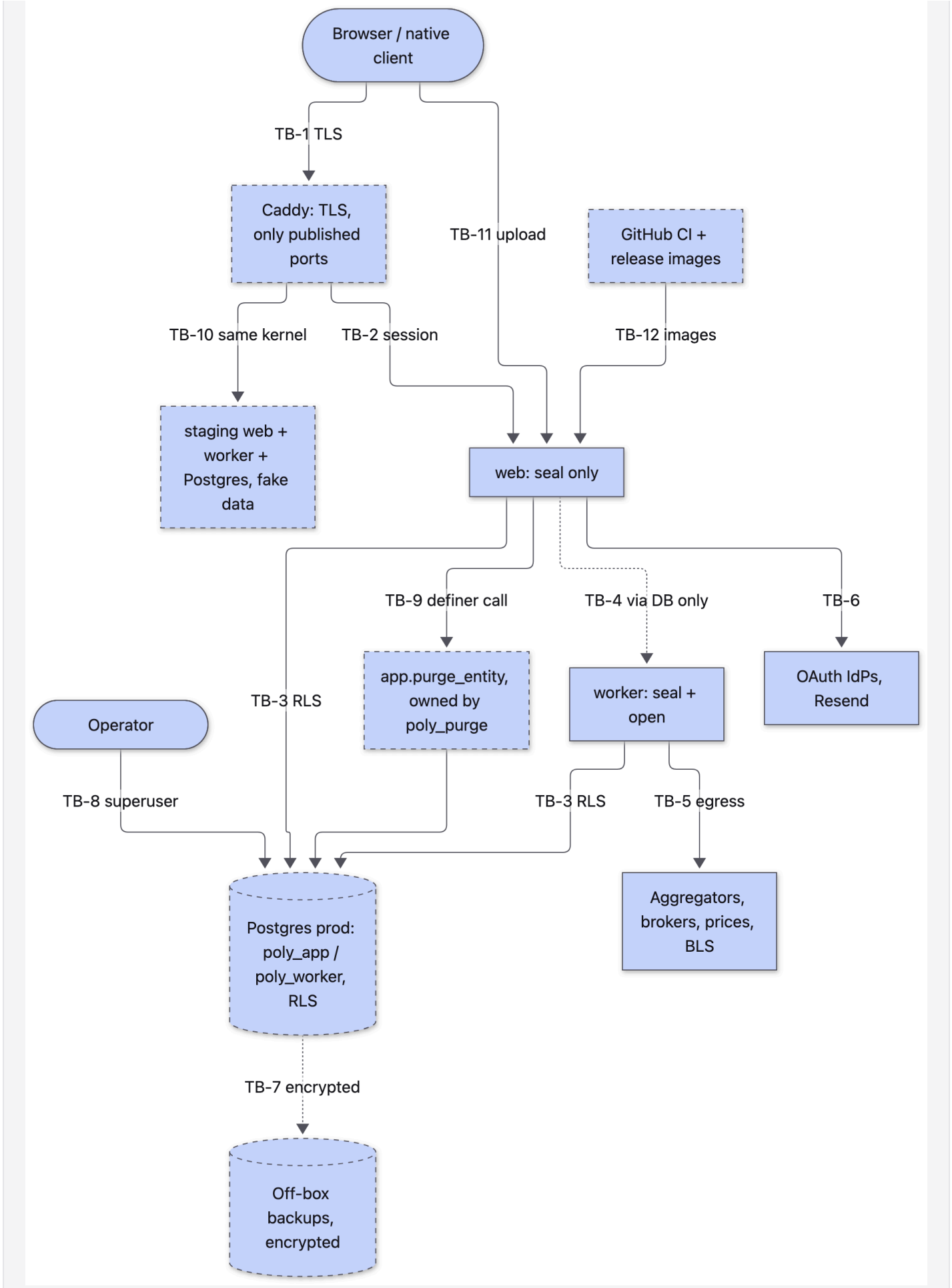
2. Trust Boundaries

ARCH §7 cites TB-1 to TB-10, so those numbers stay stable. The OQ-1 revision (§6.3) redefines TB-4. TB-11 and TB-12 are new. Each boundary becomes a threat entry in §3.

#	From	To	Boundary type	Notes
TB-1	Internet	Caddy	Network, TLS	TLS 1.2+ with HSTS. Caddy is the only container that publishes ports (80 and 443). *Local-network box (ARCH §7.8):* the "From" side is the LAN only. Nothing on the internet reaches Caddy, and the posture is C-76.
TB-2	Browser, native and MCP clients	SvelteKit `web`	Authentication	A session cookie or bearer token goes through `getSession()` and becomes a branded `SessionUserId`. Anything else is anonymous. CSRF and origin checks sit here.
TB-3	`web` / `worker`	Postgres	DB role + RLS	The primary authorization boundary. Apps connect as `poly_app` or `poly_worker`, never as the owner. Tenant context is transaction-local (§4.3).
TB-4	`web`	`worker` (the credential-opening capability)	Process + key separation	`web` can seal credentials but cannot open them; only `worker` holds the private key (§6.3). The two share only the database. *Revised:* 8963efb had a symmetric master key mounted into the app.
TB-5	`worker`	Aggregators, brokers, price and CPI providers	Egress, third-party trust	Outbound only. Credentials are opened just in time. Every response is untrusted input: payee and memo text can be written by anyone who sends the user money.
TB-6	`web`	OAuth IdPs, Resend	Third-party identit	The IdP asserts identity. Resend sees verification and magic-link URLs in transit.

#	From	To	Boundary type	Notes
			y and email	
TB-7	Box	Off-box backup store	Custody	Backups are encrypted before egress, with a key separate from the credential key (§6.6).
TB-8	Operator (SSH, `docker compose exec`)	Box, Postgres superuser	Administrative	Bypasses RLS and triggers by definition (R-1). C-24 detects what it does; it cannot prevent it.
TB-9	Ordinary write path	Purge path	Privilege (DB role)	The only path that deletes posted rows. It runs inside a function owned by the NOLOGIN `poly_purge` role (§4.5).
TB-10	Staging compose project	Prod compose project	Container isolation, shared kernel	Staging auto-deploys every merge to `main` and holds no real books. Its data is the fake source plus Plaid Sandbox and SimpleFIN demo data (Principal, 2026-11-06). It has separate networks, secrets and database. *Revised in v1.1:* staging has its own keyring, which seals sandbox tokens only, and it never holds prod's keyring or the production Plaid secret (C-77, R-4).
TB-14	Parent member (`poly_app`)	Aggregates of entities beneath the parent	Privilege (definer role)	The only path by which structure grants anything. Allowlisted definers owned by `poly_rollup` return fixed aggregate shapes, never rows. Their reads are confined by role-targeted policies to the caller's descendants. The cap-table and allocated-income definers (`poly_stake`) and the graph triggers

#	From	To	Boundary type	Notes
				(`poly_graph`) sit on the same boundary (§3.8, C-25, C-27).
TB-11	User upload (CSV / OFX)	`web` parser	Untrusted file	The credential-free import path, and a parser attack surface (C-40).
TB-12	GitHub (CI, Actions, Renovate, registry)	Release images, prod deploy	Supply chain	Whoever can publish an image that prod runs owns the box (§8).
TB-13	Operator (SSH tunnel)	Admin view listener, bound to loopback and never routed by Caddy	Administrative, out-of-band	*Placeholder; defined under POLY-81.* The design options are ARCH OQ-15: (a) a loopback route group inside `web`, or (b) a separate admin service with a read-only status DB role. The threats and controls are written when POLY-81 is ruled.


Browser / native client
TB-1 TLS
Caddy: TLS, only published ports
TB-11 upload
GitHub CI + release images
TB-10 same kernel
TB-2 session
TB-12 images
staging web + worker + Postgres, fake data
web: seal only
TB-9 definer call
TB-4 via DB only
TB-6
TB-3 RLS
app.purge_entity, owned by poly_purge
worker: seal + open
OAuth IdPs, Resend
Operator
TB-8 superuser
TB-3 RLS
TB-5 egress
Postgres prod: poly_app / poly_worker, RLS
Aggregators, brokers, prices, BLS
TB-7 encrypted
Off-box backups, encrypted

3. Threat Model (STRIDE)

One table per component group. Only threats with non-trivial likelihood × impact are listed. L = likelihood, I = impact (H/M/L). Control IDs refer to §7.

Attacker model.

- (a) An internet attacker who can reach Caddy.
- (b) A curious or malicious household member with a legitimate viewer or manager grant.
- (c) A counterparty who controls text that lands in our data. Anyone who sends the user money writes a payee or memo string.
- (d) A compromised dependency or CI path.
- (e) A thief with a backup or a disk.
- (f) An attacker with code execution in `web`. This one is in scope, and the design limits what they get.

The operator's own superuser is not modelled as an attacker (R-1).

3.1 TB-1 / TB-2 — Edge & web app (Caddy, SvelteKit, `packages/auth`)

ID	Threat	STRIDE	L	I	Control(s)
T-01	A stranger signs up on a public instance and gets an account on someone's household box.	S / E	H	M	C-01
T-02	Credential stuffing, spraying or brute force against password login.	S	M	H	C-03, C-04
T-03	OAuth account takeover: an IdP identity with an unverified email auto-links to an existing user.	S	L	H	C-05
T-04	Session cookie theft through XSS, subdomain cookie injection or the network.	S	M	H	C-02, C-07, C-41

ID	Threat	STRIDE	L	I	Control(s)
T-05	CSRF on state-changing form actions or `/api/v1`.	T / E	M	H	C-06
T-06	Stored XSS through provider payee or memo strings, or through entity or report names set by a co-member.	T / E	M	H	C-41, C-07
T-07	Account enumeration through login, reset or signup responses.	I	M	L	C-04
T-08	A stolen session is used for an irreversible or exfiltration-shaped action: purge, export, provider link, membership grant.	S / E	L	H	C-03 (step-up), C-50, C-52. A purge runs with no delay (R-16), so the controls are step-up, the typed name, a fresh export and an immediate email to every member.
T-09	Floods against expensive endpoints: reports, export, upload.	D	L	M	C-04, C-40, C-42

3.2 TB-3 — Database & tenancy (`packages/db`, `packages/tenancy`, RLS)

ID	Threat	STRIDE	L	I	Control(s)
T-10	IDOR: a route accepts an `entityId` the caller has no membership on.	I / T	H	H	C-13, C-14, C-17
T-11	A pooled connection carries tenant A's context into tenant B's request.	I	M	H	C-11, C-12
T-12	A new table ships without RLS: staging, draft, lot or some future	I	H	H	C-13 (catalog-derived battery)

ID	Threat	STRIDE	L	I	Control(s)
	table.				
T-13	RLS is bypassed through ownership: a view runs as its owner, a materialized view has no RLS, or a SECURITY DEFINER function is not on the allowlist.	I / E	M	H	C-15, C-16
T-14	A write policy without `WITH CHECK`, or an updatable `entity_id`, lets a row be inserted into or moved to another entity.	T / E	M	H	C-14
T-15	A manager grants roles, or the last owner is removed.	E	M	H	C-20
T-16	A user attaches their entity under someone else's Household, injecting rows into the victim's roll-up reports.	T / S	L	M	C-19
T-17	Existence oracle: FK checks bypass RLS, so sequential IDs let an attacker probe for other tenants' rows.	I	M	L	C-18
T-18	SQL injection in `poly_app` sets `app.user_id` to anyone. The GUC is asserted by the app, not authenticated by the database.	S / I / E	L	H	C-44 prevents it; RLS does not (R-2)
T-19	Cross-tenant metadata read through user-defined entity types. This is by design (kickoff §2.4).	I	H	L	R-9; the C-14 view exposes the label only
T-26	On a multi-owner entity (co-trustees, partners), one owner acts alone. They admit a member or raise a role, remove a co-owner, or rewrite the	E / T	M	H	C-28 (every other owner approves, enforced in the database), C-03 step-up. The founder's force path is narrow:

ID	Threat	STRIDE	L	I	Control(s)
	cap table, possibly as a 0-unit bookkeeper owner or from a hijacked owner session.				co-owner removal or demotion only, after a decline or expiry, with notice. R-19.
T-20	Membership-table policies recurse through the authz functions, or FORCE RLS blinds those functions, so policies fail open or error.	E / D	M	H	C-15 (functions owned by `poly_authz`)

3.3 Ledger integrity — tampering & repudiation (`ledger`, `securities`, `posting`)

ID	Threat	STRIDE	L	I	Control(s)
T-21	A posted entry is edited or deleted through the app role, an ad-hoc SQL session, or `TRUNCATE`. `TRUNCATE` fires no row triggers and ignores RLS.	T / R	M	H	C-21, C-10 (no TRUNCATE grant)
T-22	An unbalanced entry is committed.	T	L	H	C-22
T-23	Forged attribution: `actor_id` is set to another user.	R / S	M	M	C-23
T-24	The operator superuser disables triggers (`ALTER TABLE … DISABLE TRIGGER`, `session_replication_role = replica`) and edits history undetectably. The same applies to editing a restored backup.	T / R	L	H	C-24 (detects it, POLY-M2), R-1
T-25	A manager's `auto_post` rule posts attacker-shaped entries without review.	T	L	M	C-17 (manager+), C-23 (`actor = rule:<id>`), C-53

3.4 TB-4 / TB-5 / TB-11 — Import, adapters & credentials

ID	Threat	STRIDE	L	I	Control(s)
T-30	A DB dump or backup leaks aggregator tokens, which are standing bearer access to real bank data.	I	M	H	C-30, C-72, C-73
T-31	Code execution or SSRF in the internet-facing `web` process opens every stored credential.	I / E	L	H	C-30 (`web` holds the public key only), C-31
T-32	Sealed-blob swap: someone with DB write copies the victim's sealed token into their own connection row, and the victim's bank data flows into the attacker's entity.	T / I	L	H	C-30 (AAD binds the blob to connection, entity and provider)
T-33	A token or URL leaks into logs, errors, API responses or the stored payload.	I	H	H	C-31, C-33, C-34, C-75
T-34	Unlink deletes the local row but leaves the token live at the provider.	I	M	M	C-32
T-35	A malicious CSV or OFX: XXE, billion-laughs, oversize input, spreadsheet-formula payloads.	T / D / I	M	M	C-40, C-41
T-36	Full account numbers stored in raw payloads widen the blast radius of any read leak.	I	H	M	C-34; payload readable by manager+ only (§4.2.1)
T-37	A malicious attachment (a PDF/HTML polyglot, a forged content type, a header-injecting file name) runs in our origin, or attachments fill the disk.	T / E / D	M	M	C-46

3.5 Worker & jobs (`apps/worker`, `packages/refdata`)

ID	Threat	STRIDE	L	I	Control(s)
T-40	A job with blanket cross-tenant write: one bug corrupts every tenant.	E / T	M	H	C-60 (every tenant write has a user principal)
T-41	A job keeps importing after the linking user loses their grant or deletes their account.	E / I	M	M	C-60 (`principal_invalid`), C-52
T-42	An unauthenticated caller triggers the Vercel Cron internal route.	E / D	M	M	C-61
T-43	Tampered or garbage reference data (prices, CPI) skews valuations.	T	L	M	TLS, source priority, C-45

3.6 TB-9 — Export, account deletion, purge & audit

ID	Threat	STRIDE	L	I	Control(s)
T-50	Purge abuse: an owner who is not the sole owner, `poly_app` setting the purge GUC directly, a stale export, or writes made after the export.	T / E	L	H	C-50
T-51	The purge path deletes nothing and reports success. This happens under FORCE RLS with no DELETE policy.	T	H if built per 8963efb	H	C-50 (`poly_purge` role-targeted DELETE policies; a zero-rows-remain assertion)
T-52	The purge erases its own evidence.	R	L	M	C-53
T-53	Export files linger on disk or in temp storage.	I	M	H	C-51
T-54	PRD §5's "rewrite the actor attribution" on account deletion would mean an UPDATE on append-only rows.	T	H	M	C-52 (tombstone the user row, never the entries)

ID	Threat	STRIDE	L	I	Control(s)
T-55	An exported CSV runs a spreadsheet formula planted in a payee string.	T / E	M	M	C-41

3.7 TB-7 / TB-8 / TB-10 / TB-12 — Host, backups & supply chain

ID	Threat	STRIDE	L	I	Control(s)
T-60	Postgres or `web` is exposed publicly, because Docker-published ports bypass `ufw`.	I / E	M	H	C-70, C-71
T-61	A stolen disk, snapshot or backup exposes everything.	I	L	H	C-72, C-73
T-62	A box compromise also deletes or encrypts the off-box backups.	D / T	L	H	C-73 (append-only credential, immutable snapshots)
T-63	A compromised npm release (worm or typosquat) runs install scripts in CI or in the image.	E / I	M	H	C-80, C-82
T-64	A GitHub or Actions compromise pushes to prod through a deploy key.	E	L	H	C-81, C-83
T-65	Code merged but not yet released runs on staging on the prod kernel, then escapes its container.	E	L	H	C-70, C-74, R-4
T-66	A secret is committed to the repo or baked into an image.	I	M	H	C-82, C-74
T-67	The local box, meant to be LAN-only, becomes reachable from the internet.	I / E	M	H	C-76

ID	Threat	STRIDE	L	I	Control(s)
	Causes: a router UPnP auto-forward, a home router that allows inbound IPv6 to the box's global address, or a Docker-published port bypassing the host firewall.				
T-68	The DNS-API token on the local box, used for the DNS-01 certificate, is stolen. The thief can issue certificates for the zone, or redirect the name for clients that resolve it publicly.	S / I	L	M	C-76 (token scoped to one zone, a file secret mounted into Caddy only); R-18
T-79	Private-CA mode on the local box. The operator's root certificate is installed on every device, so whoever holds its signing key can impersonate *any* website to those devices, banks included.	S / I	L	H	C-76: a name-constrained root, the root key offline, only an intermediate on the box. R-20.
T-69	The whole local box is stolen from the home.	I	L	H	C-72: the TPM unlock is sealed to Secure Boot (P8). The disk alone is unreadable elsewhere, and the whole box boots only to an authenticated login. C-73: backups are encrypted separately. R-21.
T-76	Staging, which now holds a keyring and sandbox tokens, is configured with prod's keyring, the production Plaid secret or a real SimpleFIN token. Real bank access then lands on the box that runs unreleased code.	I / E	L	H	C-77, C-74

3.8 TB-14 — Nesting, roll-up & cap table (`poly_rollup` , `poly_stake` , `poly_graph`)

ARCH §3.1a and §3.3a–c, on the Principal's rulings of 2026-11-06/07. Access stays per entity. These are the only paths by which structure or equity yields any figure about an entity the caller holds no membership on.

ID	Threat	STRIDE	L	I	Control(s)
T-70	A parent member with no membership on a child reads the child's rows (entries, lines, payees, memos, lots, positions) through a roll-up definer, the holdings popover, or a bug in a definer body.	I	M	H	C-25
T-71	Structure enumeration: a non-member reads `entity_rollup` rows, or ancestor names, beyond the ruled grant (members of the parent; the child's owner sees parent names only).	I	M	L	C-19, C-25
T-72	Time-slicing: calling the roll-up, economic or allocated-income definer for one-day periods, or comparing balances on consecutive days, rebuilds near-transaction-level detail of an entity the caller is not a member of.	I	M	M	Consent disclosure (C-25): the inclusion step and the upward-consent notice state that any period is visible. No period guard, by the Principal's ruling (P2, 2026-11-07). R-17.

ID	Threat	STRIDE	L	I	Control(s)
T-73	The audience of an entity's totals grows without its owner knowing. It grows when the entity's parent is placed under another parent (consent travels upward), or when a member is added to an ancestor.	I	M	M	C-25: a placement notice and an ancestor-invite notice, both written by `poly_graph` triggers and both carrying the consent-disclosure sentence and the pull-out link. Also `app.parents_of` and pull-out. Notify, never block (P5, 2026-11-07).
T-74	The cap-table candidate list, or the holder notification, leaks names of Persons or entities to someone with no relation to them.	I	L	M	C-27
T-75	A holder's owners, who have no membership on the held entity, read other holders' rows or the held entity's books.	I	M	M	C-27
T-77	A cycle check or holder-graph check runs under a role that cannot see the whole graph, so a cycle through entities invisible to that role is accepted. Roll-ups then double-count, and allocations loop.	T	M	M	C-25 (graph triggers owned by `poly_graph`, with a graph-wide read)
T-78	A cycle or depth refusal reveals that a hidden link exists.	I	L	L	R-15. The inserter must own both ends, and the error names no entity.

4. Authentication & Authorization

§4.3–§4.5 are the rulings on ARCH OQ-2, OQ-3 and OQ-4. OQ-1 is ruled in §6.3. §12 has the summary and the changes against 8963efb.

4.1 Authentication

- **Provider.** BetterAuth in our own Postgres, via the Drizzle adapter. Sign-in methods:
  - Email + password, hashed with scrypt (the BetterAuth default).
  - OAuth 2.0 with PKCE and a verified `state`, via Google, Apple or GitHub.
  - Passkeys.
  - Optional magic links sent through Resend.
- **Invite-only registration (C-01).** The first user on an empty instance is the bootstrap user. After that:
  - Self-signup is off. New users arrive only through a membership invitation from an entity owner.
  - OAuth sign-in for an unknown email with no pending invite is rejected.
  - **No switch reopens public sign-up** (Principal, 2026-11-07, P6). No configuration flag or environment variable enables self-signup, so there is nothing to flip by mistake or through a configuration compromise.
  - **An invitation that shares no entity:** `polycarpic user invite <email>`.
    - Runs on the box only, by the operator, and writes an `audit_event`.
    - Creates a single-use invitation with the same expiry as an entity invitation.
    - The invitee gets only their own Person entity.
    - No entity is involved, so neither the co-owner approval (§4.2.2) nor the ancestor-invite notice applies.
- **MFA (C-03).** TOTP and passkeys, with single-use backup codes stored hashed.
  - **Ruled (Principal, 2026-11-07, P1):** MFA is required for any user holding owner or manager on any entity. It is optional for viewers (R-7). OAuth-only users must enrol a passkey or TOTP to hold those roles, because we cannot verify the IdP's MFA.
  - 8963efb recommended MFA-optional, fearing lockout with no support desk. The lockout risk has a cheaper answer: an operator-side CLI (`polycarpic user reset-mfa <email>`). It runs only on the box and writes an `audit_event`. The operator is already the trust root (R-1).
- **Step-up.** These actions require a re-authentication within the last 5 minutes (password + MFA, or a passkey):

    - purge
    - entity export
    - granting a membership or changing a role
    - linking or unlinking a provider
    - disabling MFA
    - changing email
    - deleting the account
- **Web sessions (C-02).** Server-side BetterAuth records.
    - The cookie is `__Host-`-prefixed, `HttpOnly`, `Secure` and `SameSite=Lax`.
    - Sessions expire after 7 days idle or 30 days absolute.
    - All sessions are revoked on password change, MFA reset or account deletion.
    - Membership changes need no session revocation, because visibility is recomputed from `membership` in every transaction.
- **Native and MCP tokens (later).** Named, listable, individually revocable bearer tokens.
    - Stored hashed as Tier 1, and kept in the device Keychain.
    - Scoped to a *user*, never to an entity. A token grants what its user can do at the time of each request.
- **No in-app super-admin.** No application role reads across tenants. The operator's superuser is the only such principal, and it sits outside the app (R-1).
- **Service authentication.**
    - Each service uses its own Postgres role and password, delivered as files (C-74): `web` uses `poly_app`, `worker` uses `poly_worker`, migrate uses `poly_migrator`.
    - `web` and `worker` never talk over HTTP; they coordinate through pg-boss tables.
    - On Vercel, Cron calls an internal route authenticated by `Authorization: Bearer <CRON_SECRET>`, compared with `timingSafeEqual`. The route is compiled out of the `adapter-node` build (C-61).

4.2 Authorization model

RBAC over the membership join (`user`, `entity`, `role`), enforced by Postgres RLS. A user's rights come only from `membership` rows. They never come from a `user_id` column on a data table, and never from entity structure. Access is a grant; the hierarchy grants nothing.

`can(role, action)` in `packages/tenancy` exists to render a correct UI and to return a clean 403 early. It is *not* an enforcement point.

The design test: delete every `can()` call, and the system must still be safe. Any control that fails this test is app-layer-only authorization, and the security gate rejects it.

There are two exceptions, and both are enforced in database functions rather than `can()`: step-up recency (checked by the route, and required as an argument by the purge function) and sole-owner status.

4.2.1 Permission matrix (owner / manager / viewer)

Roles are the same for every entity type. The type drives tax routing and reporting, never authorization. The matrix is stored as data in `packages/tenancy`. Every row gets a pgTAP assertion that bypasses the app layer, plus an endpoint-level test (C-17).

Action	viewer	manager	owner	Enforced by
Read dashboard, balances, posted entries, lots, reports, drafts	✓	✓	✓	SELECT policy: `entity_id = any ((select app.visible_entities()))`
Read linked-account name and last-4	✓	✓	✓	Full numbers are never stored (C-34), so there is nothing to mask per role.
Read the raw provider payload (`raw_transaction.payload`)	×	✓	✓	Policy or column grant through a manager+ view. The payload is the least-curated, most PII-dense field we hold.

Action	viewer	manager	owner	Enforced by
Read the entity's membership list	own row	✓	✓	SELECT policy on `membership`
Create, edit or delete a draft; confirm a draft (post); reverse an entry	×	✓	✓	Per-command policies with `WITH CHECK app.has_role(entity_id,'manager')`
Edit the chart of accounts; create or edit rules, including `auto_post`	×	✓	✓	As above. `auto_post` creation writes an `audit_event`.
Upload CSV / OFX	×	✓	✓	Insert policy on `import_batch` and `raw_transaction`
Link a provider connection	×	✓ step-up	✓ step-up	Insert policy on `provider_connection`. The linking user becomes `linked_by_user_id`.
Unlink a connection	×	own links only	any, step-up	Policy compares `linked_by_user_id`. Revocation runs as a worker job (C-32).
Sidebar-IA actions (ARCH §2.4 @ 884748c). G6 in ARCH §3.2a relies on these rows.				
Refresh a provider	×	✓ ste	✓ step-up	A relink stores a new sealed credential, so it is treated like a link (C-30). The policy

Action	viewer	manager	owner	Enforced by
token (relink)		p-up, own links		compares `linked_by_user_id` for managers. Writes an `audit_event`.
Map a linked account to a custodial GL account	×	✓	✓	UPDATE policy on `linked_account`: manager+. The target account must belong to the same entity (composite FK). A mapping change writes an `audit_event`, because it redirects where bank data posts.
Sync now	×	✓	✓	Enqueues a worker job and never opens the credential in `web` (TB-4). Rate-limited per connection (minimum interval set in INFRA) against provider quota and cost.
Post, Split, Group, + New entry, Correct entry	×	✓	✓	G6: `WITH CHECK app.has_role(entity_id,'manager')` on `journal_entry` / `journal_line`, with the actor forced by trigger (C-23). Correct entry is a reversal plus a new entry and never an edit (C-21). G1, G2, G4 and G5 are re-checked by the database at commit.
Rule auto-post opt-in (opting in counts as confirmation)	×	✓	✓	The opting-in user is recorded on the rule (`auto_post_by_user_id`) and is the principal for every auto-post, as in OQ-3. If that user drops below manager or is deleted, `auto_post` flips off and an `audit_event` is written, mirroring `principal_invalid`. Auto-posts pass G1–G6 like any post. Opt-in writes an `audit_event` and emails the owners.
Per-entity import	×	✓	✓	UPDATE policy on the entity's import settings: manager+. The interval is bounded

Action	viewer	manager	owner	Enforced by
schedule				below by the same INFRA minimum as Sync now.
Set entity metadata (name, tax classification)	×	×	✓	UPDATE policy on `entity`: owner
Set a parent link	×	×	✓ on child *and* parent	C-19. The `poly_graph` trigger refuses cycles and links past depth 8, and notifies every owner beneath (C-25).
Remove a parent link	×	×	✓ on child *or* parent	DELETE policy on `entity_rollup` (Principal, 2026-11-06). Writes an `audit_event`.
Read parent links; see the parents above my entity	links where a member of the parent	as viewer	as viewer, plus `app.parents_of` on an owned child	SELECT policy on `entity_rollup`: any membership on the parent, or owner on the child. `app.parents_of` returns ancestor ids and names only (C-19).
Read a parent's consolidated totals (POLY-1.1)	✓	✓	✓	`app.rollup_totals` / `app.rollup_economic`, guarded by viewer+ on the parent. Aggregates only, never rows (C-25).
Read the cap table	✓	✓	✓	SELECT policy on `equity_total` / `equity_holding` by `entity_id`. A holder's owners who are not members use `app.my_stakes()` (C-27).
Edit the cap table; read	×	×	✓ step-up; co-owner approval	INSERT policy on `equity_*`: sole owner only. With more than one owner, the edit is held

Action	viewer	manager	owner	Enforced by
holder candidates			if more than one owner	and applied only through `app.apply_change` (§4.2.2, C-28). `app.cap_table_candidates` is owner-only (C-27).
Invite a member, raise a role, add an owner	×	×	✓ step-up; co-owner approval if more than one owner	INSERT and UPDATE policies on `membership` (and `invitation`): sole owner only. Otherwise the change goes through §4.2.2. The invite email is sent only once the change applies (C-20, C-28).
Remove or demote a co-owner	×	×	✓ step-up; every other owner approves, the target included. After a decline or expiry, the founding owner may force it.	Through §4.2.2 only (`app.apply_change`, or `app.force_change` for the founder). A last-owner trigger also applies (C-20). The founder cannot be removed or demoted this way.
Transfer the founding-owner role, or step down from it	×	×	founder only, step-up	An UPDATE of `entity.founding_owner_user_id` through a `poly_govern` definer. The new founder must be a current owner. Every owner is notified, and an `audit_event` is written (§4.2.2).
Remove a viewer or manager; lower or give up one's own role	×	×	✓ step-up (own role: self, any role)	A single-owner action (Principal, P5b). DELETE and UPDATE policies on `membership`, plus the last-owner trigger (C-20).

Action	viewer	manager	owner	Enforced by
Export the entity's complete books	×	×	✓ step-up	PRD §5 grants this to the owner. It is exfiltration-shaped, so it is audited (C-51). *Revised:* 8963efb allowed manager+.
Purge the entity's books	×	×	sole owner, step-up	C-50 (§4.5)
Read the entity's `audit_event` rows	×	×	✓	SELECT policy: owner, or `actor_id = app.current_user_id()`
Clone or edit own report definitions; export own personal data; delete own account	self	self	self	Owner-user policies. Account deletion resolves every solely-owned entity in the flow, by transfer or purge, or the user aborts. The user is the only invoker (§4.6, C-52). *Revised in v1.1:* deletion was refused for a sole owner.

4.2.2 Co-owner approval on multi-owner entities (Principal, 2026-11-07, P5b)

Co-trustees and partners govern as a group. Without this rule, any one owner, including a 0-unit bookkeeper owner, could admit anyone, raise a role or rewrite ownership alone (T-26). On an entity with more than one owner, these changes need the approval of **every other current owner**:

- (a) inviting a member, or raising a role (viewer → manager → owner);
- (b) removing or demoting a co-owner;
- (c) any cap-table edit (`equity_total` , `equity_holding`).

Removing a viewer or manager, and lowering or giving up one's own role, stay single-owner actions. Sole-owner entities are unaffected.

- **A pending state, enforced in the database.**
  - **The request.** A `change_request` row holds entity, kind, payload, requester, created time, expiry and status (`pending | applied | declined | expired | withdrawn`). One `change_approval` row is written per approving owner, and both tables are append-only apart from the status.
  - **Direct writes.** `poly_app` 's direct INSERT and UPDATE on `membership` , `invitation` and `equity_*` , for the actions above, pass only while `app.owner_count(entity_id) = 1` .
  - **Multi-owner path.** Otherwise the only write path is `app.apply_change(change_id)` . It is an allowlisted definer owned by a new NOLOGIN, NOBYPASSRLS `poly_govern` role, holding role-targeted INSERT and UPDATE on exactly those tables. A `can()` -only gate fails the §4.2 design test.
- **Who approves.** The approvers are every current owner other than the requester, recomputed when the change is applied, never fixed when it is requested.
  - For a co-owner's removal or demotion, the target is one of the approvers, so no owner can be removed by the others alone. A deadlock is broken by the founding owner (below).
  - An approval counts only if its approver is still an owner at apply time.
  - One decline ends the request.
  - The requester may withdraw it.
- **Applying.** When the last approval lands, `apply_change` runs in that approver's transaction and re-validates the payload against current state:
  - the role still exists;
  - the cap-table Σ invariant holds;
  - the entity version the request was made against is unchanged, or there is no conflicting applied change since.

  If validation fails, the request is declined as stale and nothing applies. Only on apply does the invitation become live and its email go out.
- **Step-up.** Requesting, approving and declining each need a re-authentication within 5 minutes, with the second factor required for owners (C-03, P1).
- **Audit and notice.** Each step writes an `audit_event` : `change.requested` , `.approved` , `.declined` , `.withdrawn` , `.expired` and `.applied` . Every owner is notified on request and on outcome. Pending requests, including an invitee's email address, are visible to owners only.
- **The founding owner (Principal, 2026-11-07, R-19 ruling).** Each entity records one founding owner, `entity.founding_owner_user_id` , set to its creator. For a Person entity that is its own user.
  - **Always an owner.** A trigger refuses any state where the founder does not hold owner.

- **Breaking a removal deadlock.** Once a request to remove or demote a co-owner is `declined` or `expired`, the founder may force it through `app.force_change(change_id)`, a `poly_govern` definer.
  - It requires that the caller is the founder, that the kind is a co-owner removal or demotion, and that the status is declined or expired.
  - It requires a step-up within 5 minutes, with the second factor.
  - It writes a `change.forced` `audit_event` and notifies every owner, the target included.
  - The founder may raise the request themselves. The force still needs the decline or the 14-day expiry first, so the target always has warning.
- **No other extra power.** The founder has none over invites, role raises or cap-table edits, which still need every other owner. The founder is never a target of `force_change`.
- **Leaving the role.** The founder can only step down or transfer it in-app, as a founder-only action, with step-up and a notice to every owner.
  - Stepping down names a successor among the current owners.
  - A founder who would give up their own owner role must transfer the founder role first, if another owner exists.
- **Account deletion.**
  - In the in-flow deletion (§4.6), a founder of an entity with other owners must name a successor among them. The tombstone transaction refuses while any entity still names them as founder.
  - On a sole-owned entity, the transfer target becomes founder. On a purge, the question does not arise.
- **A founder who vanishes without deleting.** The backstop is the operator CLI (`polycarpic entity set-founder`, `polycarpic membership …`), which is audited and notifies every owner.

- **Edges** (SecEng rulings):
  - **An owner who never responds.**
    - A request expires 14 days after it is made, and expired counts as declined. Silence never approves.
    - Owners are reminded at day 7.
    - The requester may ask again. One open request per kind and target, and an expired request can be re-raised at most once per 7 days.
  - **An approver in the middle of account deletion.**
    - While their deletion flow runs they are still an owner and may approve or decline.

    - At their tombstone they stop being an owner, so their approvals stop counting and they stop being required.
    - Each pending request on their entities is re-evaluated. If it is now fully approved, it is *not* auto-applied: the requester is notified to confirm, with step-up.
    - Leaving an entity is giving up one's own role, so it needs no approval.
  - **The owner set changes while a request is pending.**
    - A new owner becomes a required approver.
    - A departed owner drops out, and the requester-confirm rule above applies.
  - **Bootstrap, when the second owner is added.**
    - A sole owner adds the first co-owner, by invite or by raising a member's role, as a single-owner action. There is nobody to approve.
    - The invitee's acceptance is their own consent, and they do not approve their own admission.
    - From the moment two owners exist, every further change in (a) to (c) needs approval.
    - The entity-creation default cap table, and transfer in account deletion, are sole-owner cases.
  - **Pending changes and the purge.** A purge needs a sole owner, so §4.2.2 never meets it. Pending requests on a purged entity are deleted with it, and their audit events survive.

pgTAP for the sidebar-IA rows (qa-engineer, C-17). Each row gets an allow test and a deny test, run as `poly_app` with the app layer bypassed:

- A viewer cannot run any of the actions: every INSERT or UPDATE is rejected by policy.
- A manager cannot relink or unlink another user's connection.
- A mapping to another entity's account fails the composite FK.
- An auto-post whose opting-in user has been demoted to viewer writes 0 rows, and its rule ends with `auto_post = false`.
- A "Correct entry" never UPDATEs the original; it leaves one reversal plus one new entry.
- Sync and schedule below the minimum interval are rejected.

Revocation semantics. Revoking a membership takes effect on the next transaction; there is no cached authorization. The user's sessions stay valid for their other entities. Data a client has already fetched cannot be recalled (R-11). The native milestone must purge its cache on any 401, 403 or empty scope.

4.3 RLS mechanism — ruling on ARCH §3.3 (OQ-2)

Ruling: confirmed, with amendments. These stand as designed: transaction-local GUC, STABLE SECURITY DEFINER visibility functions, ENABLE + FORCE on every tenant table, and default-deny.

Additions (a)–(d) are already in ARCH (from 8963efb) and remain in force:

- (a) The coverage probe is derived from the catalog.
- (b) No CREATE on `public`.
- (c) Per-command policies with `WITH CHECK` on every write; `FOR ALL` is banned.
- (d) The inversion canary stays.

Review found defects that (a)–(d) do not cover. Amendments (e)–(l) are new:

e. **FORCE RLS vs. the definer functions (latent defect, T-20).**
   - *The problem.* Under `FORCE`, the table *owner* is also subject to policies. ARCH has `visible_entities()` and `has_role()` owned by `poly_owner`, and they read `membership`, which is itself FORCEd.
   - *Why it breaks.* Once `membership`'s own SELECT policy calls `has_role()` (so that managers can list members), the chain function → `membership` policy → function makes Postgres raise "infinite recursion detected in policy". If the policy does not call it, the functions silently see only the rows the policy allows.
   - *Fix.* A `poly_authz` role (NOLOGIN, NOBYPASSRLS) with SELECT on `membership` and `entity_type` only, plus a role-targeted policy `CREATE POLICY authz_read ON membership FOR SELECT TO poly_authz USING (true)`. Both functions are owned by `poly_authz`. FORCE stays uniform and nothing gets BYPASSRLS. `poly_app` cannot use the policy, because it is not a member of `poly_authz`.

f. **The empty-string GUC (defect).**
   - *The problem.* 8963efb and ARCH say `current_setting('app.user_id', true)` returns NULL when unset. That is only true until the GUC is first touched in a session. After any transaction-local set, the placeholder reads back as `''`, and `''::uuid` raises. That is fail-closed, but noisy and fragile.
   - *Fix.* Every policy reads `app.current_user_id()`, which is `nullif(current_setting('app.user_id', true), '')::uuid`. The pool-reuse test runs its no-context probe on a connection that has already carried a context.

g. **`TRUNCATE` (defect).** It ignores RLS and fires no row-level DELETE triggers. *Fix:* a statement-level `BEFORE TRUNCATE` trigger that raises on every append-only table, and no login role holds TRUNCATE.

h. **Pinned search_path.**

    - Definer functions use `SET search_path = ''`, and every name is schema-qualified.
    - EXECUTE is revoked from PUBLIC and granted explicitly.
    - Policies call these functions as `(select app.fn())`, so each is evaluated once per statement as an initplan.
    - A catalog allowlist names every SECURITY DEFINER function, and any function not on it fails the battery.

i. **Immutable tenancy columns.** `entity_id`, `actor_kind` and `actor_id` are left out of `poly_app`'s column-level UPDATE grants, so no row can change tenant or author. UPDATE policies carry both `USING` and `WITH CHECK`.

j. **Views.** Every view over tenant tables is created `WITH (security_invoker = true)`. Materialized views over tenant data are banned, because RLS cannot apply to them. The battery asserts both rules.

k. **Role hygiene.** `poly_app` and `poly_worker` are NOSUPERUSER, NOBYPASSRLS and NOCREATEROLE. They have no TRUNCATE, REFERENCES or TRIGGER grants and are members of no other role. The battery checks this with `pg_has_role` and `has_table_privilege`.

l. **Non-enumerable identifiers.** Primary keys for tenant-visible rows are UUIDs (v7 is acceptable). FK checks bypass RLS, so sequential IDs would make an existence oracle. ARCH §4.1's `/entities/42` becomes a UUID.

Pool safety. `set_config(…, true)` is safe under the in-process node-postgres pool and under transaction-mode pgbouncer, including Neon's pooler. The rules that keep it safe:

- Statement-mode pooling is banned, because it breaks transactions.
- The deploy checklist asserts the pooler mode on both targets (DevOps).
- `withTenant()` refuses to nest (AsyncLocalStorage guard).
- `withTenant()` accepts only a branded `SessionUserId`, which only `packages/auth` can construct.
- The raw pool is not exported, and the layer lint enforces that.
- Session-level `SET` is banned by lint.

What RLS buys, and what it does not.

- *It buys:* authorization bugs become empty results instead of leaks. That covers a missing `WHERE`, an IDOR, a forgotten table.
- *It does not buy:* any defence against SQL injection or code execution inside `poly_app`. The GUC is app-asserted, so anyone who can run SQL as `poly_app` can set it to anyone (R-2).

- *For that case:* prevention is C-44. The blast radius is capped by C-30 (`web` cannot open credentials) and C-10 (no DDL, no TRUNCATE).

4.4 System jobs — ruling on OQ-3

Ruling: confirmed as folded into ARCH. A job's tenant writes run under the linking user's membership. No tenant policy has a system bypass clause. The requirements already on POLY-64 stand:

- `provider_connection.linked_by_user_id` is NOT NULL.
- `withSystem(job, connection, fn)` sets `app.user_id` to that user and `app.actor = system:<job>`. Authority and attribution stay separate.
- If that user's membership drops below manager, or their account is deleted, the connection flips to `principal_invalid`. That state surfaces on the dashboard, writes an `audit_event` and notifies the owners. It never fails silently.
- A job never falls back to running context-free. If no principal resolves, it errors.

Additions:

- **Entity-bound jobs with no connection** (the tax-period freeze) run under a current owner of the entity, chosen deterministically as the earliest owner membership, with `actor = system:<job>`. Every tenant write therefore has a human principal.
- **Scheduling** needs a cross-tenant list of targets. That list comes from one allowlisted SECURITY DEFINER function, `app.job_targets(job)`, which returns only (`entity_id`, `principal_user_id`, `connection_id`). Only `poly_worker` can execute it.
- **Reference-data writes** (prices, CPI, tax tables) go through role-targeted policies (`TO poly_worker`). `poly_app` gets SELECT only. A role-targeted policy cannot be unlocked by any GUC that `poly_app` sets.
- **Cash-in-Transit aging** is computed on read by the exceptions report, not stored by a job. That removes a job that would need cross-tenant reads.
- **`poly_worker` tenant DML** is limited to the import path:
  - `import_batch`, `raw_transaction`, `reported_balance`
  - `draft`, `transfer_match`
  - status columns of `provider_connection`
  - `journal_entry` / `journal_line`, for `auto_post` only
  - `tax_period_freeze`, `audit_event`

4.5 The purge path — ruling on OQ-4 (revised)

Ruling: the purge function is owned by a dedicated NOLOGIN `poly_purge` role, with role-targeted DELETE policies. This reverses 8963efb, which had the function owned by `poly_owner` and rejected a separate role. The guard order ARCH folded in is kept, with two guards added.

- **Why 8963efb's shape fails (T-51).**
  - A definer function owned by `poly_owner` runs as the table owner, and under `FORCE ROW LEVEL SECURITY` the owner is subject to policies.
  - Append-only tables deliberately have no DELETE policy. So the function would delete *zero rows and report success*.
  - Adding a `poly_owner` DELETE policy would instead hand the purge capability to the migration owner.
- **Why the separate-role objection does not hold.** 8963efb said "a role needs a credential". A NOLOGIN role has no credential; it is only the owner identity for the definer function. The entry point is just as narrow: one function, with EXECUTE granted to `poly_app`. The only change is which role's privileges the function runs with.
- **Shape.**
  - `poly_purge` is NOLOGIN and NOBYPASSRLS, with DELETE on the purgeable tables only.
  - Each purgeable table gets `CREATE POLICY purge ON <t> FOR DELETE TO poly_purge USING (entity_id = nullif(current_setting('app.purge_entity', true), '')::uuid)`.
  - The append-only triggers allow DELETE only when `current_user = 'poly_purge'` *and* `OLD.entity_id` matches the GUC. `poly_app` can set the GUC but can never become `poly_purge`.
  - `app.purge_entity(entity_id, export_id, reauth_at)` is SECURITY DEFINER, owned by `poly_purge`, with `search_path = ''`.
- **Guards, in order, in one transaction:**
  1. Re-authentication within 5 minutes. The route checks it, and the function requires the timestamp as an argument.
  2. Sole-owner check against `app.current_user_id()`.
  3. An `export.completed` audit event for this entity, by this user, within 24 hours, carrying a SHA-256.
  4. *(New.)* No tenant write to the entity since the export's snapshot marker, so a manager's later postings cannot slip past the export. The entity row is locked `FOR UPDATE`.

5. An `entity.purged` `audit_event` is written before the first delete. It records the actor, entity id and name, the export event, per-table row counts and timestamps. `audit_event` has no FK to `entity` and no purge policy.
6. Every connection is revoked at the provider. The worker revoke job must have succeeded; a failed revocation blocks the purge and is never skipped.
7. Set `app.purge_entity` transaction-locally and delete in dependency order.
8. *(New.)* Assert zero rows remain for the entity in every purgeable table before commit. This is the fail-loud guard against T-51.

- **Not permitted:**
  - purge by a job;
  - purge through the API without interactive, typed confirmation of the entity name;
  - purge of a partial date range (that is an edit, and edits are reversals);
  - purge while a second owner exists.
- **Backups:** purged data persists until the backup retention window rolls (R-5). The purge warning says so.
- **Rejected alternatives:**
  - `ALTER TABLE … DISABLE TRIGGER` is DDL. It needs an ACCESS EXCLUSIVE lock and the table owner, and it affects every tenant.
  - Tombstoning is not a purge, so it breaks the PRD §5 promise.
  - BYPASSRLS is broader than needed.
- **No execution delay (Principal, 2026-11-06, OQ-23).** SecEng had recommended a cancellable 24-hour delay against a hijacked session. The Principal ruled it out, after hearing that rationale and the architect's objections.
  - The purge runs as soon as the guards pass.
  - Every member is emailed immediately, before the entity's rows go.
  - Recorded as R-16.
- **Roll-up junction.** The `entity_rollup` purge policy matches either column, so purging an entity removes it from every parent and the parents' owners are notified (ARCH §3.4). The cap-table rows on *other* entities that name the purged entity as a holder are open: see A-19.

4.6 Account deletion in-flow — who invokes the purge (OQ-25)

Ruling: the account being deleted is the only invoker of every step. This follows ARCH §3.4a, on the Principal's ruling of 2026-11-06, which replaced the refusal for a sole owner.

- **Who.** Only the user who is deleting their account, signed in, with a fresh step-up:

    - password plus their second factor, or a passkey;
    - an OAuth-only user does a forced fresh round trip (`prompt=login`, `max_age=0`), plus their second factor (required for an owner, P1).

  Never a job, never another member, never the operator CLI. The user still holds owner when each purge runs, so the §4.5 sole-owner guard passes on its own terms, and no guard is relaxed for this flow.
- **The plan is bound to the session.** The per-entity choices (transfer to whom, purge with which export) are held server-side, keyed to the session that made them.
    - Another session, or a new sign-in, starts again from the list.
    - If the 5-minute step-up lapses mid-run, the user is prompted again. The run never continues silently.
- **Founder succession.** For each entity where the user is the founding owner and other owners remain, the flow requires a successor named among them (§4.2.2). A sole-owned entity's transfer target becomes founder.
- **Exports.** Every purge choice carries its own `export.completed` event, by this user, within 24 hours (guard 3). The flow produces these exports before the final confirmation.
- **Order.** Transfers first, then purges, then the tombstone.
    - A transfer names a current member who is not mid-deletion themselves. The recipient is notified, and the transfer writes an `audit_event`.
    - A failed provider revocation stops the run at that entity (§4.5 guard 6). Nothing later is applied.
- **Audit.** One `account.deleted` `audit_event` records every choice: the transfer targets, and each purged entity's id with its export SHA-256. It sits alongside the per-entity `entity.purged` events. All of them keep the tombstoned user id.
- **Email.** Every member of a purged entity is emailed as each purge begins (OQ-23). The departing user gets a confirmation at their address before the tombstone removes it. Every remaining member of a shared entity they leave is notified (ARCH §3.4a).
- **Tests** (C-52):
    - another member cannot drive a deletion's purge step;
    - a plan made in session A cannot be confirmed from session B;
    - a lapsed step-up blocks the next purge;
    - a failed revoke leaves the account undeleted and the remaining entities untouched;
    - the tombstone transaction refuses if a sole-owned entity appeared during the flow.

5. Data Classification & Handling

User data falls into three sensitive tiers (from the Research brief), plus two non-tenant classes. Tiers 2 and 3 together are "sensitive personal financial data". Memo and payee text routinely leaks medical, income and relationship details, so it is not "just transactions".

Everything sits on an encrypted volume (C-72) and travels only over TLS. The table covers handling beyond that baseline. Assigning a tier to a new field is a security-gate question.

Tier	Data	At rest (beyond volume encryption)	Exposure rules	Retention
T1 Authentication secrets — Restricted	Password hashes, TOTP seeds, backup codes, session records, native/MCP bearer tokens, verification and reset tokens, IdP OAuth tokens	Passwords use scrypt. Backup codes and bearer tokens are hashed. Session-token hashing and `encryptOAuthTokens` in BetterAuth are unmeasured; POLY-62 confirms them, and R-12 applies otherwise. We request no offline OAuth scopes, because we need identity only.	Never logged. Never returned after creation. Never in a URL, except single-use reset and magic links that expire after 15 minutes.	Sessions: 7 days idle, 30 days absolute. Tokens: until used or expired. All deleted on account deletion.
T2 Standing bank-access credentials — Restricted (highest value)	SimpleFIN access URLs, Plaid access tokens, broker refresh tokens	HPKE-sealed, with AAD binding (§6.3, C-30). `poly_app` has no column SELECT (C-31).	Never sent to any client in any form, not even masked or partial. Never in DTOs, logs or the raw payload. Opened only in `worker`.	Until unlink. Revoked at the provider on unlink, account deletion or purge (C-32).
T3 Financi	Balances, transactions,	RLS on the membership join. Full account	Members only, per §4.2.1. Payloads	Ledger: indefinite

Tier	Data	At rest (beyond volume encryption)	Exposure rules	Retention
al data and PII — Confid ential	payees, memos, holdings, lots, entries, tax figures, entity names and classification, account last-4, raw payloads (redacted), exports, `audit_event`, user name and email	numbers are never stored (C-34). No field-level encryption: it would break sums, ranges and reports, for a threat that volume encryption plus RLS already covers.	are manager+ only. Logs carry opaque IDs only (C-33). Exports are streamed and never persisted (C-51). Emails are visible only to co-members who are owner or manager.	(append-only) until entity purge. Raw rows follow the ledger. `audit_event`: indefinite. On account deletion, the user row becomes a tombstone (C-52).
Opera tor secret s	Credential private keys, DB passwords, Plaid secret, Resend key, BLS key, OAuth client secrets, BetterAuth secret, backup key, `CRON_SECRET`	Files under `/run/secrets`, mode 0400. Never in the repo, an image or the database (§6.2).	Never logged. Prod and staging values differ. The backup key and the credential key are never stored together.	§6.4
T4 Public referen ce	Prices, CPI-U, tax tables, system report templates	—	No tenant column.	Indefinite

No outbound user data (a control). ARCH §1 says nothing about a user's books leaves the box, except through a provider call the user initiated or an owner-initiated export. Treat that sentence as a control. Any feature that would break it needs a security review and a PRD-level decision, not just a library import. Examples: crash reporting with payloads, hosted error tracking, telemetry that includes tenant data, or an LLM call that carries transaction text.

Stored, but never logged. T3 is stored in the clear under RLS, but scrubbed from logs. Logs get tailed over SSH, pasted into bug reports and shipped to aggregators, which makes them the likeliest escape route. That is why scrubbing is enforced by a CI canary (C-33) and not left to convention.

6. Secret Management

Two populations. Operator secrets: one set per instance, held by the person running the box. User credentials: one per connection, held sealed in the database. §6.3 resolves ARCH OQ-1.

6.1 Inventory

Secret	Lives in	Mounted into	Rotation
Credential keyring (X25519 private keys, by `key_id`)	`/etc/polycarpic/secrets/credential_keyring`, plus an offline copy in the operator's password manager	`worker` only. Public keys go to `web` as non-secret config.	§6.4
Postgres role passwords (`poly_app`, `poly_worker`, `poly_migrator`)	Host secrets directory	Only the container that uses that role	On compromise or a change of operator
BetterAuth secret	Host secrets directory	`web`	On compromise. Rotating it invalidates every session, which is the intended effect in an incident.
OAuth IdP client secrets, Resend key	Host secrets directory	`web`	At the provider, on suspicion
Plaid client secret, broker OAuth clients, price-provider key, BLS key	Host secrets directory	`worker`, plus `web` for the Plaid token exchange	At the provider, on suspicion
Backup encryption key and store credential	The public half (recipient) on the box; the private half offline (§6.6)	Backup job	On a change of operator. Keep the old key until its last backup expires.

Secret	Lives in	Mounted into	Rotation
Staging credential keyring (sandbox tokens only)	The staging secrets directory, separate from prod's	Staging `worker` only	Freely: losing it means relinking sandbox items
DNS-API token (local box, real-domain mode, P7)	Host secrets directory	Caddy only	At the DNS provider, on suspicion. Scoped to one zone.
`CRON_SECRET` (Vercel only)	Vercel env var	Internal cron route	On compromise
CI deploy credential or registry token	GitHub *environment* secret, with required reviewers	Actions runner	On compromise. Revocable independently of the operator's SSH key.
Aggregator tokens and URLs (T2)	Postgres, sealed (§6.3)	Opened only in `worker`	Driven by the provider. Re-sealed on key rotation.

6.2 Operator secret handling

- **Files, not environment variables.**
  - Secrets live on the host in `/etc/polycarpic/secrets/` (root:root, files 0400, directory 0700).
  - They are mounted as compose `secrets:` at `/run/secrets/`, and apps read them through the `*_FILE` convention.
  - Why: environment variables leak through `docker inspect`, `/proc/<pid>/environ`, child processes and error reporters that dump `process.env`.
  - *Revised:* 8963efb and ARCH §9 specify a root-only env file.
- **Per-container scoping.** Each container gets only the secrets it needs. `web` never gets the credential private key or the backup key. Staging gets its own values, and its own keyring, which seals only Plaid Sandbox and SimpleFIN demo tokens. It never gets prod's keyring or the production Plaid secret (C-77). *Revised in v1.1:* staging had no keyring while it used only the fake provider.
- **Nothing in images.** No secret is ever baked into an image or passed as a build arg. `.env.example` lists names with a comment each, never values.

- **Fail closed at startup.** Outside development, the app refuses to start if a required secret is missing, or if a secret-looking env var is set in production.
- **Read once.** Secrets are read at startup. There is no runtime secret-fetch path and no admin endpoint that reveals configuration.
- **Vercel.** The tertiary target uses Vercel's encrypted env vars (R-3). The hosting order is Hetzner, then the local box, then Vercel + Neon (Principal, 2026-11-06).
- **Local box.** Same file layout as the Hetzner path. In real-domain mode (P7) the DNS-API token is a file secret mounted into Caddy only, scoped to one zone (C-76).

6.3 Credential sealing — ruling on OQ-1 (revised)

Ruling: app-layer *asymmetric* sealing in `packages/secrets`. `web` holds only public keys; the private keyring is mounted into `worker` only.

This replaces 8963efb's symmetric envelope scheme, which ARCH §3.1 and TB-4 folded in: an AES-256-GCM DEK wrapped by a master key mounted into the app. The seam is unchanged: `seal()` / `open()` with a `key_id`. Rejecting pgcrypto and external KMS still stands (§6.5).

- **Why revise.**
  - With a symmetric master key, whoever seals can also open. The sealing process is `web`, because it receives the SimpleFIN setup token or the Plaid public token.
  - `web` is also the internet-facing process, and the most likely place for RCE or SSRF. So one `web` compromise would yield every bank token (T-31).
  - Asymmetric sealing removes that path at about the same implementation cost.
- **Algorithm.** HPKE (RFC 9180) base mode: DHKEM(X25519, HKDF-SHA256), HKDF-SHA256, AES-256-GCM. The library (e.g. `@hpke/core`, or an equivalent over `node:crypto`) is pinned in the `packages/secrets` design file, with SecEng sign-off. No home-rolled construction.
- **Binding.** The HPKE `aad` is the canonical encoding of (`connection_id`, `entity_id`, `provider`, `key_id`, `alg_version`). A blob copied to another row fails to open (T-32).
- **Stored columns.** `enc` (the encapsulated key), `ciphertext`, `key_id`, `alg_version`. These replace ARCH §3.1's "ciphertext + nonce + wrapped DEK + key_id".
- **Flows.**
  - *Link* (in `web`): receive the setup or public token, exchange it with the provider, `seal()` the result under the active public key, insert the row, drop the plaintext.
  - *Poll* (in `worker`): `open()` inside one call frame, for one provider call. The plaintext is never cached and never held in a module-level variable.

    - *Unlink*: `web` enqueues a revoke job. `worker` opens the credential, calls `adapter.revoke()`, then deletes (C-32).
- **Database enforcement.** `poly_app` has column INSERT and UPDATE on the sealed columns, but no SELECT. `poly_worker` has SELECT. The columns never appear in DTOs or `openapi.json` (C-31).
- **Errors.** Provider errors are re-thrown with the credential stripped. A raw provider exception never reaches a response or a log without passing through the scrubber.
- **Import boundary.** A lint boundary rule forbids any package except `packages/secrets` from importing the crypto module. Only `apps/worker` may import `open()`.

6.4 Key rotation for an operator with no KMS

1. Run `polycarpic secrets rotate` in `worker`. It generates key *n+1*, adds it to the keyring, and publishes its public key as the active sealing key.
2. It re-seals every row with `key_id = n`: open with *n*, seal with *n+1*. The step is idempotent and resumable.
3. It asserts that zero rows remain under key *n*, removes *n*, and writes an `audit_event`.
4. When to rotate: on any suspicion that the worker, the box, the operator's SSH key, or a backup together with the keyring was compromised, and whenever the operator changes. Annual rotation is optional hygiene. If the keyring *and* the database may both be exposed, rotation alone is not enough: revoke every token at the provider and relink (RB-1).

A lost keyring means relinking, not data loss. Every connection shows "relink required". The ledger is not encrypted under this key. The runbook says this plainly, so that nobody stores the key next to the backup "to be safe". The keyring is never part of the backup set.

6.5 Why not pgcrypto, and why not a secrets manager

- **pgcrypto (rejected).** The key and the plaintext would pass through SQL. That puts them in `pg_stat_activity`, potentially in statement logs, and in the same process as the data. A stolen dump must yield inert ciphertext. With the key co-located, it does not.
- **Vault or a cloud KMS (rejected for v1).** On a single VPS, a vault's unseal material sits on the same box. So it adds a service for a novice operator to run without adding real separation. It would also break the near-zero-spend guardrail and add an availability dependency. The `key_id` seam leaves room for a KMS-backed keyring later; revisit if R-6 ever triggers.
- **The credential-free path stays the recommended default.** The CSV/OFX adapter stores no credential. An instance that never links an aggregator holds zero T2 data. The operator

runbook presents linking as a convenience trade-off.

6.6 Backup key custody — owned by DevOps (ARCH OQ-9)

Requirements on INFRA:

- Backups are encrypted on the box before they leave it.
- The key can be recovered without the VPS.
- The key is distinct from the credential keyring, and the two are never stored together.

Recommended shape:

- An asymmetric recipient (age-style), so the box holds only the public half.
- A write-only or append-only store credential, or immutable snapshots.

With that shape, a fully compromised box can neither read nor delete its own historical backups. The acceptance test is a restore onto a clean machine. RPO and RTO numbers are DevOps's call.

7. Controls Catalog

Each control maps to threats in §3. No application code exists yet, so Status names the milestone where the control must land. A feature that touches a control cannot pass the Validate security gate without it. Control IDs are new in this rewrite; 8963efb's C-numbers are retired.

ID	Control, location and test	Threats	Status
C-01	Invite-only registration after the bootstrap user. OAuth sign-in for an unknown email is rejected unless an invite is pending. There is no reopen switch (P6). The operator CLI `polycarpic user invite <email>` issues an audited invitation that shares no entity. **Lives at:** `packages/auth` hooks; worker CLI **Tested by:** Integration: • a 2nd signup is rejected; • OAuth for an unknown email is rejected; • an invite accept works; • a CLI invite yields a user with only their own Person, and writes an `audit_event`; • a config scan finds no self-signup flag.	T-01	POLY-M1
C-02	Session cookie is `__Host-`, `HttpOnly`, `Secure`, `SameSite=Lax`. 7 days idle, 30 days absolute. All sessions revoked on a password or MFA change. **Lives at:** `packages/auth` config **Tested by:** Playwright `Set-Cookie` assertions; config unit test.	T-04	POLY-M1
C-03	MFA (TOTP, passkeys) per §4.1. Step-up re-auth within 5 minutes on the listed actions. Operator MFA-reset CLI, audited. **Lives at:** `packages/auth`; the `requireRecentAuth()` guard; worker CLI **Tested by:** Integration: every step-up action returns 403 without a recent re-auth; the CLI writes an `audit_event`.	T-02, T-08	POLY-M1 (MFA, required for owner and manager per P1), then with each gated feature

ID	Control, location and test	Threats	Status
C-04	BetterAuth `rateLimit` with database storage (e.g. sign-in 5/min per IP and per email). Generic auth error messages. Body-size limits on every route. **Lives at:** `packages/auth`; `hooks.server.ts` **Tested by:** Integration: the 6th attempt returns 429; responses for known and unknown emails are identical.	T-02, T-07, T-09	POLY-M1
C-05	OAuth uses PKCE and `state`. Accounts link only when the IdP asserts a verified email *and* there is either an existing session or a matching pending invite. **Lives at:** `packages/auth` **Tested by:** Integration: a mocked IdP sending `email_verified=false` does not link.	T-03	POLY-M1
C-06	`kit.csrf.checkOrigin = true`, never disabled. Mutating `/api/v1` routes accept JSON only. SameSite cookies. **Lives at:** `svelte.config.js`; `/api/v1` wrapper **Tested by:** Integration: a cross-origin form POST is rejected; `text/plain` returns 415.	T-05	POLY-M1
C-07	CSP through `kit.csp`: nonce or hash, no `unsafe-inline` script, `frame-ancestors 'none'`, `object-src 'none'`. HSTS for 1 year at Caddy. `nosniff`. `Referrer-Policy: strict-origin-when-cross-origin`. **Lives at:** `svelte.config.js`; Caddyfile **Tested by:** Header assertions in the Playwright smoke run.	T-04, T-06	POLY-M1
C-10	Role separation and hygiene per §4.3(k), including `poly_authz` and `poly_purge`. No TRUNCATE, REFERENCES or TRIGGER grants to login roles. No CREATE on `public`. **Lives at:** `packages/db` role migrations **Tested by:** pgTAP catalog assertions.	T-13, T-21	POLY-M1
C-11	`withTenant()`: `set_config('app.user_id', …, true)` as the first statement; branded `SessionUserId`; nesting guard; raw pool not exported; session-level `SET`	T-11	POLY-M1

ID	Control, location and test	Threats	Status
	banned by lint; pooler-mode assertion in the deploy checklist. **Lives at:** `packages/db` ; INFRA checklist **Tested by:** pgTAP pool-reuse test (tenant A, then tenant B on the same backend, sees 0 of A's rows); Vitest: a nested call throws.		
C-12	Fail-closed context: `app.current_user_id() = nullif(current_setting('app.user_id', true), '')::uuid` . **Lives at:** `packages/db` SQL **Tested by:** pgTAP: on a backend that already carried a context, a query with no context returns 0 rows on every tenant table and raises no error.	T-11	POLY-M1
C-13	ENABLE + FORCE RLS and at least one policy on every table with a tenant column. The probe is catalog-derived, with an inversion canary. The global-table allowlist is a security-gate decision. **Lives at:** `packages/db` battery **Tested by:** pgTAP in CI; the build fails if any table is uncovered.	T-10, T-12	POLY-M1
C-14	Per-command policies with `WITH CHECK` ; no `FOR ALL` . Tenancy and actor columns are not updatable. No DELETE policies on append-only tables. The entity-type exception goes through a label-only `security_invoker` view. **Lives at:** `packages/db` schema **Tested by:** pgTAP: a viewer INSERT is denied; an insert with a forged `entity_id` is denied; an `UPDATE` of `entity_id` gets permission denied.	T-10, T-14, T-19	POLY-M1
C-15	Authz functions are owned by `poly_authz` , with a role-targeted policy on `membership` . Every definer function sets `search_path = ''` and has EXECUTE revoked from PUBLIC. SECURITY DEFINER functions are allowlisted. **Lives at:** `packages/db` **Tested by:** pgTAP: the set of `prosecdef` functions equals the	T-13, T-20	POLY-M1

ID	Control, location and test	Threats	Status
	allowlist; `proconfig` pins `search_path`; a manager can list members without recursion.		
C-16	Views are `security_invoker = true`. No materialized views over tenant data. **Lives at:** `packages/db` **Tested by:** pgTAP catalog check on `reloptions` and `relkind`.	T-13	POLY-M1
C-17	The §4.2.1 matrix is stored as data. QA generates an endpoint × role test matrix, and a route with no matrix row fails CI. **Lives at:** `packages/tenancy`; QA suite **Tested by:** Generated Vitest + pgTAP tests; coverage check.	T-10, T-25	POLY-M1, growing with each feature
C-18	Tenant-visible primary keys are UUIDs. No sequential IDs in URLs or the API. **Lives at:** `packages/db` schema **Tested by:** Schema test: every tenant PK has type `uuid`.	T-17	POLY-M1
C-19	Parent links (amended in v1.1, OQ-19): • **Insert** needs owner on both the child and the parent. This is unchanged, and it is what stops T-16. • **Delete** needs owner on either end. • **Read.** A link is readable with any membership on the parent, or owner on the child. `app.parents_of(entity_id)` returns ancestor ids and display names, with the direct parents marked, to the child's owner only. • **No `poly_app` or `poly_worker` tenant policy reads `entity_rollup`.** Structure grants no row. The only policies that consult it are the role-targeted ones of `poly_rollup` (C-25). **Lives at:** `packages/tenancy`; `entity_rollup` policies **Tested by:** pgTAP: • owner of the child only is denied the insert; • a member of the parent sees no child rows;	T-16, T-71	POLY-M1 (junction); `parents_of` with POLY-1.1

ID	Control, location and test	Threats	Status
	• a non-member reads no link; • `parents_of` returns names only, and nothing to a non-owner; • a catalog check that no policy for `poly_app` or `poly_worker` references `entity_rollup`.		
C-25	Roll-up and graph definers (OQ-19, OQ-25): • **`poly_rollup`** owns `app.rollup_totals`, `app.rollup_economic`, `app.rollup_tree` and `app.parents_of`. ◦ NOLOGIN, NOBYPASSRLS, owns no tables, SELECT only. ◦ Its role-targeted policies are confined to `app.rollup_descendants()` (plus the equity rows of one-link entity holders of those entities, for weighting), and, for `parents_of`, to the ancestors of entities the caller owns. ◦ Results come back through a fixed `RETURNS TABLE` of aggregates by entity, report line and currency: never an account, entry, line, payee, memo, lot or position. ◦ The guard is viewer+ on the parent. ◦ `rollup_economic` takes no Person argument. • **`poly_graph`** (new) owns the BEFORE INSERT trigger functions `app.check_rollup_edge()` and `app.check_equity_holding()`. ◦ It has graph-wide SELECT on `entity_rollup` and `equity_holding`, SELECT on owner `membership` rows and `entity.kind`, and INSERT on `notification`. ◦ The wide read is acceptable because a function returning `trigger` cannot be called to return data. ◦ Refusals name no entity (R-15). ◦ Both triggers take the advisory lock.	T-70, T-71, T-72, T-73, T-77, T-78	Triggers with the junction (POLY-M1); definers and popover with POLY-1.1

ID	Control, location and test	Threats	Status

- **Placement notice.** A notice goes to every owner beneath, in the same transaction, with an `audit_event`. It names the new top-level parent and says what becomes visible.
- **Ancestor-invite notice (P5, 2026-11-07).** When an invitation to a parent becomes live (after any §4.2.2 approval, before the invitee's first sign-in), every owner of every entity beneath that parent, at any depth, gets a notification. It is written in the same transaction by a `poly_graph` trigger (AFTER INSERT on `invitation`, and on `membership` for a membership created without one, deduplicated per person).
  - It names the parent and the new member, and carries the consent-disclosure sentence and the pull-out link.
  - Any role triggers it, because viewers see totals too.
  - A later role raise on the parent does not.
  - Nothing waits on the recipients.
- **Consent disclosure (P2, 2026-11-07).** The inclusion step (adding an entity to a parent) and the upward-consent notice both state plainly that:
  - parent members see class and category totals for *any* period;
  - for a small entity that effectively reveals individual amounts and their dates;
  - nothing else is shown: no payee, memo, account or counterparty.

  The wording is a security requirement. Changing it needs a security-gate review. Any date range is allowed: there is no period guard.
- **Holdings popover on a parent.** Positions come only through ordinary `poly_app` RLS, for the parent's own accounts and for entities where the viewer is a

ID	Control, location and test	Threats	Status
	member. Any other entity shows its total and the boundary panel. No definer returns a position. • All of these functions are on the definer allowlist (C-15) and in the role-hygiene set (C-10). **Lives at:** `packages/db` SQL; `packages/tenancy` **Tested by:** pgTAP (ARCH §3.3a–c tests, plus): • a parent viewer without child membership gets totals equal to the child owner's figures, and 0 rows from every tenant table and from the popover's position read for that child; • a cycle through an entity invisible to both the inserter and `poly_rollup` is refused; • Playwright: the inclusion step, the placement notice and the ancestor-invite notice render the consent-disclosure text; • pgTAP: an invitation going live on a Holding notifies the owners of a Person two levels down whom the inviter cannot see, and a role raise does not; • calling a `poly_graph` function directly fails; • the result-column set of each `poly_rollup` function equals its pinned shape.		
C-27	Cap table and allocated income, under the new `poly_stake` role (NOLOGIN, NOBYPASSRLS, owns no tables, SELECT only; OQ-25): • **`app.cap_table_candidates(entity_id)`** is for an owner of `entity_id` only. It returns the id and display name of members' own Persons, and of Person, Trust and Business entities visible to the caller. Nothing else. • **`app.my_stakes()`** is a holder's owners' read path. It returns entity id, display name, units, total units and effective-from, for holder entities the caller owns (or the caller's own Person). Other holders' rows are	T-74, T-75	POLY-1.0 (tax allocation); `my_stakes` with the cap-table editor

ID	Control, location and test	Threats	Status
	never returned. The `equity_*` SELECT policies are not widened for non-members. • **`app.allocated_income(taxpayer_entity_id, from, to)`** returns income totals by tax tag × stake, never rows. ◦ Its reads are confined by role-targeted policies to `app.held_entities()`: entities in which the caller's own Person, or an entity the caller owns, has ever held units, plus one link onward. ◦ Guard: the caller has a membership on the taxpayer entity. • **Holder notification** is written by the `poly_graph` trigger (C-25). **Lives at:** `packages/db` SQL; `packages/tax` **Tested by:** pgTAP (ARCH §3.1a tests, plus): • a non-owner calling `cap_table_candidates` gets 0 rows; • `my_stakes` returns only the caller's holder rows; • a holder's owner reads 0 rows from `equity_holding` directly on a held entity where they are not a member; • `allocated_income` returns totals equal to Σ(tagged income × stake), and 0 rows for an entity outside `held_entities()`.		
C-20	Only owners change membership. A trigger keeps at least one owner (except during purge). Every change writes an `audit_event`. With more than one owner, the actions in §4.2.2 go through C-28. **Lives at:** `packages/tenancy`; trigger **Tested by:** pgTAP: a manager's grant is denied; removing the last owner raises.	T-15	POLY-M1
C-28	Co-owner approval (§4.2.2, P5b): • `change_request` and `change_approval` tables.	T-26, T-15	POLY-1.0 (sharing, POLY-70); the cap-

ID	Control, location and test	Threats	Status
	• Direct `poly_app` writes for (a) to (c) pass only while `app.owner_count = 1`. • `app.apply_change` is owned by `poly_govern`. It recomputes the approvers at apply time and re-validates the payload. • Requests expire after 14 days. Step-up on request, approve and decline. An audit event at every step. • The invite email is sent only on apply. • The founding owner, with `app.force_change`, can force only co-owner removal or demotion, after a decline or expiry. Transfer is founder-only, and the founder must hold owner. **Lives at:** `packages/tenancy`; `packages/db` SQL **Tested by:** pgTAP: • with 2 owners, a direct membership INSERT, a role raise or an `equity_holding` INSERT by one owner is denied; • `apply_change` with one approval missing is denied; • an approval by an ex-owner does not count; • a decline or an expiry blocks; • a stale cap-table payload is declined; • a sole owner's invite applies at once; • removing a viewer stays single-owner; • `force_change` by a non-founder, on a pending request, on an invite or a cap-table edit, or targeting the founder, is denied; • a forced removal notifies the target and writes `change.forced`; • the founder cannot drop their owner role without first transferring the founder role; • the tombstone is refused while the user is still the founder of a multi-owner entity. Integration: no invite email before apply; each step without a recent re-auth returns 403.		table edit with the editor

ID	Control, location and test	Threats	Status
C-21	Append-only: row-level BEFORE UPDATE/DELETE triggers plus a statement-level BEFORE TRUNCATE trigger. The only exception is `current_user = 'poly_purge'` together with a matching `app.purge_entity`. **Lives at:** `packages/db` SQL **Tested by:** pgTAP: UPDATE, DELETE and TRUNCATE all raise for `poly_app`, `poly_worker` and `poly_owner`; `poly_app` with the GUC set still raises.	T-21, T-50	POLY-M2
C-22	Deferred balance constraint trigger (ARCH §3.2). **Lives at:** `packages/ledger` SQL **Tested by:** pgTAP + property-based tests.	T-22	POLY-M2
C-23	A BEFORE INSERT trigger *forces* the actor from the session context. `actor_kind = user` requires `actor_id = app.current_user_id()`. **Lives at:** `packages/db` SQL **Tested by:** pgTAP: a forged `actor_id` is overwritten or rejected.	T-23, T-25	POLY-M2
C-24	Per-entity ledger hash chain (Principal, 2026-11-07, P4): • **Hash.** `entry_hash = sha256(prev_hash ‖ canonical(entry, its lines))`, in `journal_number` order per entity. The canonical encoding is pinned and versioned: field order, numeric text form and UTF-8 NFC. • **When it is written.** The hash covers the lines, so it is written at commit by a deferred constraint trigger, after the balance check. It goes into an append-only `journal_chain` row (entity, `journal_number`, entry, `prev_hash`, `entry_hash`, `alg_version`). The posted entry is never UPDATEd. The chain head sits on `entity_journal_counter`, whose row lock already serializes an entity's postings. • **Who writes it.** `poly_app` and `poly_worker` cannot write `journal_chain` or the head directly; only the	T-24	POLY-M2 (with the ledger)

ID	Control, location and test	Threats	Status
	trigger does. • **Verifier.** A weekly job recomputes each entity's chain. A break writes an `audit_event` and emails the entity's owners and the operator, as SEV1 ledger tampering (§10). • **Exports.** Every export carries the chain head (`journal_number` , `entry_hash`), and the `export.completed` audit event records it. • **Purge.** A purge deletes the entity's chain, and the `entity.purged` event records the final head. • **Limits.** A superuser can recompute the whole chain. Detection therefore rests on a head held off the box: an export the owner keeps (R-1). **Lives at:** `packages/ledger` SQL; worker verifier job; export module **Tested by:** pgTAP and integration: • an edit made as superuser (triggers disabled) to an entry, a line or the order is detected by the verifier; • a rolled-back posting leaves no chain row and no gap; • `poly_app` cannot insert or update `journal_chain` ; • an export's head matches the verifier's; • a correction (reversal plus replacement) takes two chain links.		
C-30	HPKE sealing with AAD binding. `web` seals, `worker` opens; keys are held in a keyring by `key_id` (§6.3). **Lives at:** `packages/secrets` **Tested by:** Unit: round trip works; a swapped AAD, tampered ciphertext or unknown `key_id` all fail closed. Integration: the `web` container has no keyring file.	T-30, T-31, T-32	Seam in POLY-M2; first real use in POLY-1.0 (POLY-77)
C-31	`poly_app` has no SELECT on the sealed columns. DTOs and the OpenAPI spec omit them. **Lives at:** `packages/db` ; DTOs **Tested by:** pgTAP: permission denied. OpenAPI freshness diff.	T-31, T-33	POLY-M2

ID	Control, location and test	Threats	Status
C-32	Unlink enqueues a worker revoke job. The row stays `revoke_pending` until the provider confirms, with retries and backoff; a failure is surfaced to the user. Every step writes an `audit_event`. **Lives at:** `packages/import`; worker **Tested by:** Integration: when the fake provider's revoke returns 500, the row is not deleted.	T-34	POLY-M2 (fake provider), POLY-1.0
C-33	Logs are safe by construction. Pino serializers log only declared fields, and `redact` covers known paths. Never logged: bodies, `Cookie`, `Authorization`, SQL parameters, memo, payee. **Lives at:** Shared logger package **Tested by:** **Canary test:** the integration run seeds canary token, URL, account-number and memo values. CI captures every log line and fails if any canary appears.	T-33	POLY-M1 (harness), extended with each adapter
C-34	Adapters redact full account numbers, PANs and credential-bearing fields from stored payloads, keeping last-4 only. Payloads are readable by manager+ only. **Lives at:** Each `packages/import-*` **Tested by:** Per-adapter fixture containing canary numbers; pgTAP: a viewer cannot read the payload.	T-33, T-36	POLY-M2, POLY-1.0
C-35	`polycarpic secrets rotate` (§6.4). **Lives at:** `packages/secrets` CLI **Tested by:** Integration: after rotation every row opens under the new key and none under the old.	T-30, T-31	POLY-1.0
C-40	Upload caps (e.g. 10 MB, 50k rows). OFX 2.x parsed with DTD and external entities disabled; OFX 1.x parsed with a non-XML parser. No eval. **Lives at:** File adapter **Tested by:** Unit: XXE and billion-laughs fixtures are rejected; an oversize file returns 413.	T-35, T-09	With the file adapter (POLY-77)
C-41	Svelte escaping. `{@html}` is lint-banned everywhere except one sanitizing component. CSV export neutralizes any cell starting with `= + - @`, tab or CR.	T-06, T-55	POLY-M1 (lint), then with the

ID	Control, location and test	Threats	Status
	Lives at: `packages/ui` lint; export module **Tested by:** Unit: a `=HYPERLINK(…)` cell exports inert. Playwright: a `<script>` payee renders as text.		export feature
C-42	The report formula engine parses formulas to an AST over an account allowlist. `eval` and `new Function` are banned. Node-count, depth and time caps apply. **Lives at:** `packages/reports` **Tested by:** Unit: pathological and malicious formulas are rejected.	T-09	POLY-M5
C-43	Zod validates every route and form action. Unknown keys are stripped; a mismatch returns 400. **Lives at:** `apps/web` wrapper **Tested by:** Unit tests on the wrapper.	T-10, T-14	POLY-M1
C-44	Parameterized queries only. Lint bans `sql.raw()` and `sql.unsafe` with non-literal arguments. Raw SQL is allowed only in reviewed migrations. CodeQL `js/sql-injection` runs in CI. **Lives at:** ESLint; CI **Tested by:** Lint + CodeQL.	T-18	POLY-M1
C-45	Reference-data anomaly flag: a price move over 50% day-over-day, or an out-of-bounds CPI revision, is stored but flagged. **Lives at:** `packages/refdata` **Tested by:** Unit.	T-43	POLY-M4
C-46	Attachments (ARCH §3.5 @ fcffe6c): • Stored as `bytea` under RLS. The bytes live in `attachment_blob`, separate from the metadata. • Size limit of 10 MB. Type is sniffed server-side against an allowlist; the client-declared type is never trusted. • Served only as a download: `Content-Disposition: attachment` with an RFC 6266 sanitized `filename*`, plus `nosniff` and a CSP of `default-src 'none'; sandbox`. • Composite entity FKs on attachments and their links.	T-37	With the attachments feature

ID	Control, location and test	Threats	Status
	• Insert-only, and included in the purge. • Per-entity storage quota and upload rate limit. • File contents are never parsed. **Lives at:** `packages/attachments` (per ARCH) **Tested by:** Integration: a spoofed type is rejected; a file name containing CR/LF is sanitized; response header assertions; a cross-entity link is denied; purge leaves 0 attachment rows.		
C-50	Purge per §4.5: the `poly_purge` role, 8 guards checked in order, and a typed confirmation. **Lives at:** `app.purge_entity`; tenancy route **Tested by:** pgTAP: a non-sole owner is denied; a stale export is denied; a write after the export is denied; `poly_app` with the GUC set is denied outside the function; a successful purge leaves 0 rows in every purgeable table plus 1 `audit_event`.	T-50, T-51, T-08	The purge feature (POLY-1.0 scope)
C-51	Export is streamed, never persisted. If it has to run async, the file is encrypted in temp storage and expires after 24 h. Owner only, with step-up; audited with a SHA-256; rate-limited. **Lives at:** Export module **Tested by:** Integration: no file remains after download.	T-53	The export feature
C-52	Account deletion: the user row becomes a tombstone; ledger rows are never UPDATEd. BetterAuth `deleteUser` is overridden. Sessions, accounts, MFA and passkeys are deleted. Linked credentials are revoked, and the user's connections go `principal_invalid`. *Revised in v1.1 (ARCH §3.4a):* each solely-owned entity is resolved in the flow by transfer to a named current member, or by a purge through C-50, or the user aborts. The deleting user is the only invoker (§4.6). The tombstone transaction re-checks that no sole-owned entity remains. **Lives at:** `packages/auth` override; tenancy **Tested by:** Integration: • entries remain and resolve to "deleted user"; • the §4.6 negatives; • abort before the final confirmation changes nothing.	T-41, T-54	POLY-1.0

ID	Control, location and test	Threats	Status
C-53	`audit_event` is append-only, has no purge exception and no FK to `entity`. Readable by owners and by the acting user. **Lives at:** `packages/db` **Tested by:** pgTAP: the row survives a purge and cannot be updated.	T-52, T-25	POLY-M1 (the table), then events with each feature
C-60	Job principal per §4.4: `linked_by_user_id`, `principal_invalid`, no context-free fallback, `app.job_targets()`, role-targeted reference-data policies, restricted `poly_worker` grants. **Lives at:** `packages/db`; `apps/worker` **Tested by:** pgTAP: a job whose linker was revoked writes 0 rows and flips the connection's state; `poly_app` cannot write reference data.	T-40, T-41	POLY-M2 (POLY-64)
C-61	Vercel topology (OQ-13): two Vercel projects from the same repo. • `web` exposes only user routes. It holds only the public keys and the `poly_app` DB credentials. • `jobs` exposes only cron job routes. Each route checks `CRON_SECRET` with `timingSafeEqual`. It holds the keyring and the `poly_worker` credentials. • Job routes are absent from the node build and from the `web` project. **Lives at:** `apps/web`, `apps/worker` (Vercel entry) **Tested by:** Build tests: • the route manifest of each project equals its allowlist; • the `web` build contains no keyring reference; • the node build returns 404 for job routes. Env check in CI: `web` has no keyring variable.	T-42, T-31	POLY-M1 (split); keyring before POLY-77

ID	Control, location and test	Threats	Status
C-70	Only Caddy publishes ports. Prod and staging use separate compose networks. No Docker socket mounts. Containers run non-root, `read_only`, with `cap_drop: [ALL]` and `no-new-privileges`. **Lives at:** `compose.yml` (DevOps) **Tested by:** Compose policy lint in CI; a post-deploy external port scan shows only 22, 80 and 443.	T-60, T-65	POLY-M1 (INFRA)
C-71	SSH is key-only, with no root login. Unattended security upgrades. The firewall is the Hetzner Cloud Firewall, which sits outside the host, so Docker cannot bypass it. This covers the Hetzner target; the local box uses C-76 instead. **Lives at:** INFRA provisioning **Tested by:** Provisioning check script.	T-60	POLY-M1 (INFRA)
C-72	The Postgres volume and local backup staging sit on an encrypted (LUKS) volume. **Local box: unlocked automatically by the TPM** (Principal, 2026-11-07, P8): • LUKS2, with a TPM2 key slot (`systemd-cryptenroll --tpm2-pcrs=7`, plus PCR 11 where the distro ships a unified kernel image; unmeasured per distro), sealed to the Secure Boot state. Booting any other OS or kernel changes the PCRs, and the disk stays locked. • A second, recovery passphrase key slot, kept offline in the operator's password manager, never on the box. • Firmware hardening: ◦ Secure Boot on; ◦ a firmware setup password; ◦ boot from USB or network disabled. • Console hardening: ◦ no console autologin; ◦ the initrd emergency shell and single-user mode require the root password, so an unlocked disk is never handed to a console without authentication.	T-61, T-69	INFRA v1; the local-box variant before the first home-box deploy

ID	Control, location and test	Threats	Status
	Lives at: INFRA **Tested by:** Runbook verification.		
C-73	Backups per §6.6: asymmetric recipient, a key separate from the keyring, an append-only or immutable store, and a monthly restore drill. **Local box (Principal, 2026-11-07, P9):** a nightly backup, encrypted on the box, to an append-only internet storage box (a Hetzner Storage Box or equivalent). The box's credential can add backups but never delete or overwrite them. A rotated removable drive is optional, never required, and is never kept beside the box. The off-box restore drill applies unchanged. **Lives at:** ARCH §7.2 @ 6b2f11b: nightly `pg_dump` plus WAL, each encrypted to an age recipient; Hetzner Storage Box with an append-only subaccount, or S3 Object Lock **Tested by:** A monthly restore drill, run *off the box* because the private key never touches the VPS; a test that the store credential cannot delete.	T-61, T-62	Specified in ARCH; lands in POLY-M1 (INFRA); the local-box variant before the first home-box deploy
C-74	Secrets are files, scoped per container (§6.2). Staging has its own distinct values and its own keyring (C-77). The app refuses to start if a secret is missing. No secrets in images. **Lives at:** INFRA; config loader **Tested by:** Trivy secret scan; config-loader unit test.	T-66, T-31	POLY-M1
C-75	Postgres logging: `log_parameter_max_length = 0`, `log_parameter_max_length_on_error = 0`, `log_statement = 'ddl'`. **Lives at:** Postgres config **Tested by:** Config assertion in the battery.	T-33	POLY-M1
C-76	Local-network box posture (OQ-24, ARCH §7.8). This replaces C-71's cloud firewall on that target: • **Router.** No port forwarded, and UPnP/NAT-PMP disabled on the router. • **IPv6.** The box's IPv6 is disabled, or the host firewall drops all inbound IPv6. A home router may pass inbound IPv6 to a global address.	T-60, T-67, T-68, T-79	Before the first local-box deploy

ID	Control, location and test	Threats	Status

- **Host firewall.** nftables, default-deny inbound. Allowed in: 443 (and an 80 redirect) and SSH from the LAN CIDR only.
- **Ports.** Caddy is the only published port, bound to the LAN address (`"<lan-ip>:443:443"`). A `DOCKER-USER` chain rule drops non-LAN sources, because Docker-published ports bypass ufw.
- **Outbound.** Limited to DNS, NTP and HTTPS (443).
- **SSH.** Key-only, no root login.
- **Updates.** Unattended security upgrades.
- **Monitoring.** An outbound heartbeat, and its absence alerts.
- **Remote access.** None from outside the LAN in v1. A VPN later is a new security review.
- **TLS: two modes** (Principal, 2026-11-07, P7). Plain-http sign-in is refused in both: Caddy redirects 80 to 443, and the app rejects any auth route reached over plain http, trusting the forwarded protocol only from Caddy. `__Host-` cookies need `Secure` anyway.
  - **Default, real-domain mode.**
    - A subdomain of a domain the operator owns, resolved only on the LAN (split-horizon). There is no public A or AAAA record.
    - A DNS-01 wildcard certificate (`*.home.<domain>`), so the box's own name stays out of public CT logs.
    - The registrar or DNS-API token is limited to that one zone, a file secret mounted into Caddy only (R-18).
    - Google and Apple sign-in work.
  - **Supported fallback, `.local` with a private CA.**
    - The operator runs a private CA and installs its root on each device. The root carries X.509 `nameConstraints` permitting only the box's name. Browser enforcement of constraints on a locally installed root is unmeasured.

ID	Control, location and test	Threats	Status

Measuring it, for each supported browser, is a **gate item for the first home-box deploy** (R-20).

- The root key is generated off the box and kept offline (the operator's password manager). The box holds only a name-constrained intermediate that issues short-lived leaf certificates (T-79, R-20).
- The mode is explicit configuration (`TLS_MODE=private-ca`). At startup the app cross-checks it: a public name that does not resolve publicly, or that ends in `.local`, must be in private-CA mode, or the app refuses to start.
- In private-CA mode the Google and Apple buttons are hidden *and* the OAuth routes return 404 server-side. Sign-in is email + password + the second step (P1).
- Whether passkeys work on a `.local` RP ID is unmeasured; TOTP is always offered.

◦ **Moving a `.local` box to a real domain later.**

- Every session ends, because cookies are host-bound.
- Passkeys do not survive, because they are bound to the old RP ID. Before the move, the runbook requires each owner and manager to hold TOTP or backup codes, with the operator's `reset-mfa` CLI as the fallback.
- Google or Apple sign-in is then added by linking from Settings while signed in (C-05: an existing session and a verified email). It is never auto-linked by email.
- Every device should remove the old private root.

Lives at: INFRA local-box provisioning (DevOps)
Tested by:

ID	Control, location and test	Threats	Status
	• a provisioning check script (nftables rules, the `DOCKER-USER` rule, the publish binding, the sshd config); • an outside-in scan, from a host off the LAN, of the home's public IPv4 and the box's IPv6 address, showing nothing open; • a test that an outbound connection to a non-allowed port fails; • an auth route over plain http is refused in both modes; • in private-CA mode the OAuth routes return 404, and a `.local` name outside private-CA mode refuses to start; • a certificate for an out-of-constraint name issued under the private root is rejected by each supported browser.		
C-77	Staging credential isolation (ARCH §7.5, Principal, 2026-11-06): • **Its own keyring.** Staging's keyring has distinct `key_id`s, lives in its own secrets directory, and is mounted into staging `worker` only. • **Sandbox secret only.** Staging holds Plaid's sandbox secret, never the production secret. The `client_id` is shared across Plaid environments, and the secret is not. • **Startup checks.** Staging refuses to start unless `PLAID_ENV=sandbox`. Prod refuses to start with sandbox. • **SimpleFIN on staging** accepts only access URLs whose host is the demo bridge (exact host unmeasured; pinned at POLY-77). • **No real data.** No real credential may ever be linked on staging. **Lives at:** config loader; `packages/import-plaid`, `packages/import-simplefin`; INFRA	T-76, T-65	POLY-77 (the first real adapter on staging)

ID	Control, location and test	Threats	Status
	Tested by: Config-loader unit tests for both refusals; an adapter unit test rejecting a non-demo SimpleFIN host under `APP_ENV=staging`; a provisioning check that the staging and prod secret directories share no file.		
C-80–83	Supply chain (§8). **Lives at:** CI **Tested by:** §8	T-63, T-64, T-66	POLY-M1

8. CI/CD Security

- **C-80 Dependencies.**
  - Installs use `pnpm install --frozen-lockfile`.
  - pnpm lifecycle scripts are blocked, with an explicit `onlyBuiltDependencies` allowlist.
  - `minimumReleaseAge` is at least 3 days in both pnpm and Renovate, so a freshly compromised release has time to be yanked before we pick it up.
  - Renovate never auto-merges major versions.
  - `pnpm audit --audit-level high` gates the build.
- **C-81 Workflow hardening.**
  - Actions are pinned by commit SHA.
  - Workflows default to `permissions: contents: read`, and widen per job only.
  - No `pull_request_target` that runs untrusted code.
  - No secrets are exposed to fork PRs.
- **C-82 Scanning.**
  - gitleaks runs in CI and as a pre-commit hook.
  - CodeQL (JS/TS) runs on PRs.
  - Trivy scans images and fails the build on fixable critical or high findings and on embedded secrets.
  - Each release carries a CycloneDX SBOM.
  - Each release image gets an `actions/attest-build-provenance` attestation.
  - No DAST in v1 (R-13).
- **C-83 Deploy path. Pull-based: adopted in ARCH §8.1 @ 6b2f11b.** A systemd timer on the box pulls the image by digest and verifies its build attestation before migrating. The attestation must be pinned to this repository and the release workflow, e.g. `gh attestation verify --repo richmosko/polycarpic --signer-workflow …`. A prod tag is accepted only if its signature verifies against the allowed signers file. The box holds a read-only token scoped to this repository with an expiry, or no token at all if the image package is public. The superseded push-over-SSH conditions are kept for reference:
  - the key is prod-only;
  - `authorized_keys` locks it to a `command=` forced script, with `no-pty` and `no-port-forwarding`;
  - the key lives in a GitHub environment with required reviewers;
  - staging uses a separate key.

- **Signing.** `/merge-pr` signs release tags (SSH signing) before the first prod deploy, because a tag triggers deployment. Per-commit signing is not required (R-10).

9. Logging, Monitoring & Detection

- **Logged:** request ID, user UUID, entity UUID, route, action, outcome, latency, job name and run ID.
- **Never logged:** T1 or T2 values, request or response bodies, memo or payee text, amounts, emails, cookies, `Authorization`, SQL parameters. The C-33 canary test enforces this.
- **Storage and retention.** JSON logs stay on the box, rotated, for 30 days. Postgres logging is set per C-75. An optional OTel export must pass through the same serializers.
- **Operator alerts**, sent by email through Resend:
  - more than 20 sign-in failures in 10 minutes;
  - MFA disabled, or a new passkey added;
  - a membership grant;
  - a provider link or unlink;
  - an export or a purge;
  - 3 failures of a revoke job;
  - a connection going `principal_invalid`;
  - a backup failure, or no successful backup within the RPO;
  - an RLS battery failure on deploy (this also blocks the deploy);
  - more than 50 authz denials or empty scopes per user in 10 minutes.

  The thresholds are provisional and unmeasured; tune them after POLY-M1. *Revised:* 8963efb accepted no alerting at all (its R-2). Email on these events costs almost nothing.
- **User-facing notices.** Users get an email for a sign-in from a new device, a password or MFA change, and being granted or removed from an entity.
- **Audit.** `audit_event` (C-53) survives purge. The journal actor columns (C-23) are the ledger's own audit trail. C-24, the per-entity hash chain, makes ledger edits detectable. A weekly verifier checks it, and every export carries the chain head.

10. Incident Response

- **On call:** each instance's operator. For the Principal's instance, that is the Principal. Alerts arrive by email (§9).
- **Severity:**
  - **SEV1**: suspected T1 or T2 exposure, or keyring exposure; a confirmed cross-tenant read or write; code execution on the box; ledger tampering detected.
  - **SEV2**: T3 exposure limited to one user; no backup within the RPO; a revoke that cannot complete; a critical CVE with a known exploit in a deployed dependency.
  - **SEV3**: a vulnerability with no evidence of exploitation; a threshold breach that turns out benign.
- **Runbooks.** These cover the security content only; exact commands live in the INFRA runbook.
  - **RB-1: keyring or worker compromise (SEV1).**
    1. Stop `worker`.
    2. Revoke every token at its provider: Plaid `/item/remove`, SimpleFIN bridge revocation, broker OAuth revoke. If the database and the keyring may both have been exposed, treat every token as burned.
    3. Generate a new keyring.
    4. Relink every connection.
    5. Rotate the provider API secrets.
    6. Review `audit_event` and the logs for credential opens that happened outside import runs.
  - **RB-2: web or box compromise (SEV1).**
    1. Put Caddy into maintenance mode.
    2. Snapshot the volume for forensics.
    3. Rotate every operator secret, including the BetterAuth secret. This invalidates all sessions.
    4. If the worker or the keyring was reachable, run RB-1.
    5. Rebuild from a clean, attested image on a fresh host.
    6. Restore the last backup taken before the compromise, and verify it against the C-24 chain and against the head of the last export the owner holds off the box.
  - **RB-3: cross-tenant leak bug (SEV1).**
    1. Disable the affected route.
    2. Add the failing case to the RLS battery or the authz matrix *before* fixing it.

3. Identify affected users from request logs, by route and user ID.
4. Notify the affected members.

- **RB-4: lost keyring (SEV3).** Generate a new keyring. Every connection then shows "relink required". The ledger is unaffected.
- **RB-5: backup failure or restore (SEV2).** Follow INFRA. Restore to staging first, and run the balance and hash verifier before promoting.
- **RB-6: compromised dependency (SEV1 or SEV2).**
  1. Pin to the last known-good version.
  2. Rebuild and redeploy.
  3. Diff the SBOMs to check whether the bad version shipped in a release image.
  4. If it did, run RB-2.

- **Post-incident:** a blameless postmortem within 5 business days as a cairn issue comment or review file (location per `process/WORKFLOW.md`). Record decisions in process/DECISIONS.md. The regression test lands with the fix.

11. Open Risks (Accepted)

Each risk has a rationale, a compensating control, a re-evaluation date and an approver. The rows pending before 2026-11-07 were approved together that day (P3). Later rows show their own status. ARCH cites R-1 and R-4, and both keep their meaning; the other numbers are reassigned from 8963efb.

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
R-1	The operator's superuser, and root on the box, bypass RLS. They can also disable the append-only triggers (`ALTER TABLE … DISABLE TRIGGER` , `session_replication_role`) and read the keyring.	The operator owns the box, the volume and the keys. No database control can bind them (PRD §6). *Corrected:* 8963efb said the triggers still stop the superuser. They do not.	C-24 hash chain (POLY-M2, P4): silent edits become detectable, and the chain head goes into every export. Superuser access only through `docker compose exec` or an SSH tunnel. C-71.	On any decision to host for others	Rich Mosko approved the principle (PRD §6, 2026-09-27), and re-confirmed it on the corrected text (2026-11-07, P3)
R-2	RLS does not stop SQL injection or code execution in `poly_app` ,	Binding the GUC to a DB-verified session token would gain little:	C-44 (parameterized SQL, lint, CodeQL); C-30 (`web` cannot	2027-03-31	Rich Mosko (2026

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
	because the app itself asserts the tenant GUC.	`poly_app` has to read the session table for auth anyway.	open credentials); C-10 (no DDL or TRUNCATE).		-11-07, P3)
R-3	On Vercel, both projects live in one Vercel account. Anyone with access to that account or team, or a leaked Vercel token with env-read scope, can read the `jobs` keyring. Vercel functions are also public HTTPS endpoints, so the `jobs` project is reachable from the internet. It is guarded only by `CRON_SECRET`, with no user input. *Narrowed by OQ-13:* the web/worker split is kept.	Vercel is the tertiary, last-resort target (Principal, 2026-11-06). The residual risk is administrative (account-level), not a web-process compromise.	Separate projects and env scopes (C-61). Vercel account MFA and least-privilege team membership. Rotate `CRON_SECRET` on suspicion. If the two-project split proves infeasible, Vercel may run only the fake or CSV adapters, never a real aggregator credential. Hobby-plan cron runs at most once a day (measured, ARCH §7.6 @ e3b4297). On Vercel, provider-side revocation after an unlink can therefore lag up to about 24 h, and the token stays live at the provider until then. The unlink UI must say so.	Before POLY-77 ships on Vercel	Rich Mosko (2026-11-07, P3)
R-4	Staging shares the prod kernel and auto-deploys unreleased code from	It saves a second box. Staging's data	C-70 (separate compose networks, non-root, read-only	ARCH §7.2 @ 6b2f11	Rich Mosko

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
	`main` (TB-10). *Updated in v1.1:* staging now holds its own keyring and Plaid Sandbox / SimpleFIN demo tokens (Principal, 2026-11-06).	and tokens reach no real bank, so what is at risk is a pivot into prod, not staging's own data.	containers, no Docker socket); C-74 (distinct secrets); C-77 (staging's own keyring, sandbox secret only, refuses production endpoints); staging sits behind Caddy basic auth or an IP allowlist (ARCH §7.1).	b keeps staging co-located. Re-evaluate if staging ever touches non-fake data, or the app is offered at larger scale.	(2026-11-07, P3)
R-5	Purged entity data persists in backups until the retention window rolls.	Rewriting encrypted backups is disproportionate.	The purge warning says so. INFRA bounds retention.	INFRA v1	Rich Mosko (2026-11-07, P3)

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
R-6	The multi-tenant design leaves a hosted offering possible. Reversing the non-goal would bring in GLBA, state privacy law and possibly PCI, and would make R-1, R-2 and R-13 unacceptable.	Hosting for others is a standing non-goal (PRD §3).	This row makes any reversal a deliberate, costed decision that re-opens §1.	Only on a deliberate decision to host	Rich Mosko (PRD §3, 2026-09-27)
R-7	Viewers are not required to use MFA. Owners and managers are (P1).	Viewers cannot mutate data, link credentials or grant access.	C-04 rate limiting; onboarding leads with OAuth; new-device email (§9).	GA	Rich Mosko (2026-11-07, P1)
R-8	Losing the keyring makes sealed credentials unrecoverable, and rotation is a manual operator step.	Automating rotation would mean storing the new key somewhere automation can reach. Unrecoverable is the right failure mode here, because recovery is simply relinking.	The rotate command is idempotent and resumable (C-35); the runbook states the failure mode plainly; the ledger is not encrypted under this key.	Annually	Rich Mosko (2026-11-07, P3)
R-9	User-defined entity types are readable across tenants, by anyone with a membership on an entity of that type (kickoff §2.4).	A viewer needs the type label to render the entity.	A narrow policy plus a `security_invoker` view expose the label and tax defaults only, never	If types ever carry more	Rich Mosko (2026-11-

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
			the creator ID (C-14). Users are told that custom type names are shared.	than a label	07, P3)
R-10	Commits are unsigned.	With per-agent worktree identities, commit signatures prove little. Branch protection already prevents unreviewed merges.	Branch protection (admins included, no force-push, required `cairn` check). Release tags are signed (§8).	First prod deploy	Rich Mosko (2026-11-07, P3)
R-11	Revoking a grant does not recall data a client already fetched: an open browser tab now, the native cache later.	This is inherent to any client. The next request is denied.	The native milestone must purge its cache on 401, 403 or an empty scope. SecEng reviews that milestone.	Native milestone	Rich Mosko (2026-11-07, P3)
R-12	*Conditional, unmeasured.* If BetterAuth stores session tokens unhashed, anyone with DB read can hijack sessions.	This needs DB read access, which already exposes T3.	Short sessions (C-02); step-up for sensitive actions (C-03). POLY-62 measures this and closes or confirms the row.	POLY-62	Rich Mosko (2026-11-07, P3)
R-13	No DAST, WAF or penetration test.	The surface is small and sits behind Caddy, and no regime requires one.	The RLS battery; SAST, dependency, secret and image scanning (§8); this threat model is	GA	Rich Mosko (2026-11-

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
		pgTAP asserts the high-value properties more precisely than a scanner would.	reviewed at every milestone.		07, P3)
R-14	Cross-root read access (PT-3, tooling). `cairn serve` reads directories named in a committed `roots:` config (or `--repos`), which can be outside the repo. A malicious `roots:` entry in a PR could point a reviewer's local board at a sibling directory, e.g. `../../.ssh`.	The server is read-only and localhost-only, with no write path to a secondary root. The `/api/board` payload carries only parsed cairn frontmatter, so there is no exfiltration channel. A directory without a `config.yml` is skipped before anything is read. Anyone who can commit a `roots:` entry already has a stronger vector, editing `cairn.py` or `board.js` directly, so a runtime path-jail	When more than one root loads, a startup stderr banner logs each resolved absolute root path. It is a human tripwire against a stale or mistyped `roots:` entry silently serving the wrong tracker. Re-evaluate if cairn ever gains a write path to non-primary roots.	2027-02-21	Rich Mosko

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
		would be theater.			
R-15	A parent-link or cap-table refusal ("would make an entity its own ancestor", "too deep") reveals that some link exists, possibly through entities the user cannot see (T-78).	The inserter must own both ends, so the bit is about paths between their own entities. The error names no entity, and naming nothing would make the refusal unexplainable.	Errors name no entity (C-25). Refusals are audited.	If links ever become insertable by a non-owner	Rich Mosko (2026-11-07, P3)
R-16	A purge, including one inside an account deletion, runs immediately with no cancellable delay. A hijacked session that passes step-up can destroy an entity's books at once.	The Principal's ruling (OQ-23). A delay needs a background purge the design forbids, and would make the freshness guards stale.	Step-up within 5 minutes (C-03, with a second factor required for owners, P1). Typed entity name. A fresh export by the same user. Every member emailed immediately. Operator backups (C-73). R-5 bounds how long recovery is possible.	If a purge is ever reported as unwanted	Rich Mosko (2026-11-06, OQ-23)
R-19	Hostile or captured founder. Other owners cannot remove the founding owner in-app. A founder, or someone in control of the founder's	Without a tie-breaker, a two-owner dispute blocks forever. The founder's extra power is	Step-up with the second factor (C-03, P1). The decline or expiry wait. A notice to every owner, the target	On the first reported forced	Rich Mosko (2026-11-07)

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
	session, can force out co-owners one by one, each after a decline or the 14-day expiry. *Replaces* the earlier deadlock text: the founder now breaks removal deadlocks (Principal, 2026-11-07).	limited to co-owner removal or demotion, and is never immediate.	included, plus `change.forced` audit events (C-28). No extra founder power over invites, roles or the cap table. The operator CLI as the backstop.	removal	
R-18	Real-domain mode on the local box keeps a zone-limited DNS-API token on the box (T-68). Whoever steals it can issue certificates for that zone, or publish records in it.	It is what keeps Google and Apple sign-in on a box nothing can reach. The box is unreachable from the internet, so a stolen token gets no path in.	The token is scoped to one zone and mounted into Caddy only (C-76). It is rotated at the provider on suspicion. CT-log monitoring of the zone is optional.	On any change to the local-box TLS mode	Rich Mosko (2026-11-07, P7)
R-20	Private-CA mode installs an operator root on each device (T-79). If browsers do not enforce its name constraint, a stolen root key could impersonate any site to those devices.	It is the supported fallback for an operator without a domain (P7).	A name-constrained root, its key offline, and only an intermediate on the box (C-76). The runbook says to remove the root from every device on decommission or on a move to a real domain.	At the first private-CA deploy, after measuring constraint enforcement. That measuremen	Rich Mosko (2026-11-07)

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
				t is a gate item for the first home-box deploy.	
R-21	With TPM auto-unlock, a thief who takes the *whole* home box gets a machine that boots and unlocks its disk. The data is then protected only by OS login, SSH keys and app authentication, and remains exposed to an OS or service exploit, or to cold-boot and DMA attacks on the running machine.	The Principal's choice (P8). A passphrase at boot would leave the box down after every power cut. Theft of a whole box from a home is rare, and a pulled disk stays unreadable.	C-72: sealed to Secure Boot, firmware password, no USB boot, no unauthenticated console. Unattended updates (C-76). Backups encrypted separately (C-73). On theft, run RB-2: rotate every secret and revoke every bank token.	If the box moves out of the home, or holds data for others	Rich Mosko (2026-11-07, P8)
R-17	Aggregate inference. Roll-up figures shown to a parent's members, the economic view, and allocated income shown to a holder's owners can be combined to infer things. Dividing economic by gross gives the viewer's own look-through stake. Allocated income divided by stake	Each figure is one the viewer is entitled to by the Principal's rulings. Inclusion in a parent is an explicit grant by the entity's owner, so the exposure is consented, provided the	Consent disclosure at inclusion and in the upward-consent notice (C-25). The fixed aggregate shapes (C-25, C-27). Own and member entities are unaffected.	With POLY-1.1, and on any cross-parent "my net worth" proposal	Rich Mosko (2026-11-07, P2)

#	Risk	Why acceptable	Compensating control	Re-evaluate by	Approved by
	gives a pass-through entity's tagged income totals, as a K-1 tells a partner. Observing "today" figures every day accumulates detail over time. *Widened by P2:* a parent member may request roll-up totals for any date range. For a small entity, one-day periods and day-to-day balance differences reveal individual amounts and their dates, though never payee, memo, account or counterparty.	consent is honest.		(OQ-29)	

12. Rulings on ARCH Open Questions

12.1 Final rulings

OQ	Ruling	vs. 8963efb (as folded in ARCH @ eaa825e)	Detail
OQ-1	App-layer **asymmetric** sealing: HPKE with X25519, HKDF-SHA256 and AES-256-GCM. The AAD binds each credential to its connection, entity and provider. `web` seals; only `worker` holds the private keyring and can open. pgcrypto and KMS are rejected. Rotation is a re-seal job.	**Revised.** Under the old design, the symmetric master key was reachable from `web`.	§6.3–§6.5; C-30, C-31, C-35
OQ-2	ARCH §3.3 is confirmed, and additions (a)–(d) stand. This review adds (e)–(l): • (e) authz functions owned by `poly_authz`; • (f) context read as `nullif(…,'')`; • (g) TRUNCATE triggers; • (h) `search_path = ''` plus a definer-function allowlist; • (i) tenancy columns not updatable; • (j) views are `security_invoker`, with no materialized views; • (k) role hygiene; • (l) UUID keys. The permission matrix is the same for every entity type.	**Extended.** Export becomes owner-only, per PRD §5. Payload access stays manager+.	§4.2.1, §4.3; C-10 to C-20
OQ-3	Confirmed: the linking user is the job principal, `principal_invalid` exists, and there is no system clause. Additions: • entity-bound jobs run as the earliest owner; • a new `app.job_targets()` function; • reference-data policies are role-targeted; • Cash-in-Transit aging is computed on read.	**Extended.** The POLY-64 scope comment stays valid.	§4.4; C-60

OQ	Ruling	vs. 8963efb (as folded in ARCH @ eaa825e)	Detail
OQ-4	The purge function is SECURITY DEFINER, owned by a **NOLOGIN** `poly_purge` role. It uses role-targeted DELETE policies, and the append-only trigger makes an exception only when `current_user = 'poly_purge'`. ARCH's guard order is kept, plus two new guards: no writes since the export, and an assertion that zero rows remain.	**Revised.** A purge owned by `poly_owner` deletes zero rows under FORCE RLS (T-51).	§4.5; C-21, C-50
OQ-19	C-19 amended. The owner-on-both insert rule is kept. No `poly_app` or `poly_worker` policy reads `entity_rollup`; only `poly_rollup`'s role-targeted policies do, behind fixed aggregate shapes. The one-bit refusal disclosure is accepted (R-15).	**New in v1.1.** *Finding:* the cycle trigger must not be owned by `poly_rollup`, whose confined reads would miss a cycle outside the caller's descendants. Hence `poly_graph` (A-16).	§3.8; C-19, C-25
OQ-23	Recorded: no purge delay (Principal). The guards stand and every member is emailed immediately.	Q2 withdrawn	§4.5; R-16
OQ-24	Local-box posture C-76: router with no forward and UPnP off; IPv6 closed; a host nftables default-deny with a LAN-only allow; Caddy bound to the LAN address plus a `DOCKER-USER` rule; outbound limited to DNS, NTP and HTTPS; an outbound heartbeat. TLS: two modes, a real domain by default with a `.local` private-CA fallback (P7). Disk unlock: TPM (P8). Backups: nightly, to an append-only internet storage box (P9).	**New.**	C-76; T-67 to T-69
OQ-25	Confirmed, with the shapes in §3.8: • **Junction read and `parents_of`.** Read with any membership on the parent, or owner on the child. `parents_of` returns names only, to the owner only.	**New.** ARCH's "owners of a holder read their row" policy becomes the `app.my_stakes()` definer (A-18).	§3.8, §4.6; C-25, C-27, C-

OQ	Ruling	vs. 8963efb (as folded in ARCH @ eaa825e)	Detail
	• **Upward consent.** The notice names the new top parent and what becomes visible. • **OQ-18 grain at depth.** Unchanged: depth widens who sees, never what. • **Holdings popover.** Ordinary RLS only. • **Cap table.** Candidates, holder read path and notification go to `poly_stake` and `poly_graph`. • **Economic view.** It discloses only the viewer's own look-through stake. • **Allocated income.** A `poly_stake` definer, totals only. • **Staging keyring.** C-77. • **Deletion purge invoker.** §4.6, C-52.		52, C-77

12.2 ARCH changes to re-fold (architect)

#	ARCH §	Change
A-1	§3.3	`visible_entities()` and `has_role()` are owned by `poly_authz`, with a role-targeted SELECT policy on `membership`. Add `poly_authz` and `poly_purge` to the role list.
A-2	§3.4	The purge function is owned by `poly_purge`. Add the role-targeted DELETE policies and key the trigger exception on `current_user`. Add guards 4 and 8. Replace the text "a separate purge role … rejected".
A-3	§3.3	Use the `nullif` form of `app.current_user_id()`. Correct the claim "unset returns NULL". The pool-reuse test must run on a backend that has already been used.
A-4	§3.2	Add BEFORE TRUNCATE statement triggers. No login role holds TRUNCATE.
A-	§3.2	The actor is forced by trigger, not merely defaulted. `actor_kind = user` requires `actor_id = app.current_user_id()`.

#	ARCH §	Change
5		
A-6	§3.1, §4.1	Tenant-visible primary keys are UUIDs. Replace `/entities/42`.
A-7	§3.1 `provider_connection`; §2.2 `packages/secrets`; §7 TB-4; §9	The sealed columns become `enc`, `ciphertext`, `key_id` and `alg_version`. `seal()` lives in `web`; `open()` lives only in `worker`. TB-4 becomes the web ↔ worker boundary. Revocation on unlink runs as a worker job. Operator secrets are files, not an env file.
A-8	§3.1 user; PRD §5 wording	On account deletion, the `user` row becomes a tombstone and entries are never UPDATEd. `actor_id` FKs are `ON DELETE NO ACTION`. Override BetterAuth's `deleteUser`.
A-9	§2.3 RawTxn	Adapters redact full account numbers, PANs and credential fields from the stored payload.
A-10	§3.3	Views are `security_invoker`, with no materialized views over tenant data. Tenancy and actor columns are not updatable.
A-11	§3.1 entity	A parent link requires owner on both the child and the parent.
A-12	§3.3 system jobs	Entity-bound jobs run as the earliest owner. Add `app.job_targets()`. Cash-in-Transit aging is computed on read.
A-13	§6.2 / POLY-76	Add spike acceptance criterion (e): FORCE RLS, a role-targeted `pgPolicy` (`to:`), and a definer function owned by a non-owner NOLOGIN role must round-trip through `generate` and apply as `poly_migrator`.

#	ARCH §	Change
A-14	§3.1, §5 (*gap*)	Attachments appear in PRD §5 export and purge but have no storage design. They need: a location; size and type limits; serving with `Content-Disposition: attachment` and `nosniff`; and inclusion in both purge and export.
A-15	§7 TB list	Add TB-11 (upload ↔ parser) and TB-12 (supply chain ↔ prod).
A-16	§3.3b, §3.1a, §3.3 roles	`app.check_rollup_edge()` and `app.check_equity_holding()` are owned by a new NOLOGIN, NOBYPASSRLS `poly_graph` role. It has graph-wide SELECT on `entity_rollup` and `equity_holding`, SELECT on owner `membership` rows and `entity.kind`, and INSERT on `notification`. Add it to the role list. Add a test: a cycle through an entity invisible to `poly_rollup`'s predicate is refused.
A-17	§3.1 `entity_rollup` row	`app.parents_of` is owned by `poly_rollup`, under a second role-targeted predicate: ancestors of entities the caller owns. It is on the allowlist.
A-18	§3.1a "Who reads", §4.5 "The read", §3.3 roles	Add a new NOLOGIN, NOBYPASSRLS `poly_stake` role. It owns `app.cap_table_candidates`, `app.allocated_income` and a new `app.my_stakes()`. That function replaces the holder-owner SELECT widening on `equity_*`. Reads are confined to `app.held_entities()` (and, for candidates, to members' own Persons). See C-27.
A-19	§3.4, §3.1a (*gap*)	Purging an entity that is a *holder* on other entities' cap tables. Those `equity_holding` rows are append-only, and they are the other entity's history. SecEng proposes: • the purged entity's row becomes a tombstone (as the user row does), so those rows still resolve, to "former holder"; • its units allocate as outside owners from the purge date; • the owners of each affected entity are notified. Shape needed before POLY-1.0.
A-	§3.1 membership and	Co-owner approval (P5b, SECURITY §4.2.2): • `change_request` and `change_approval` tables;

#	ARCH §	Change
20	invitation, §3.1a "Who writes", §3.3 roles	• direct writes to `membership`, `invitation` and `equity_*` gated on `app.owner_count = 1`; • a new NOLOGIN `poly_govern` role owning `app.apply_change`, with role-targeted writes on those tables; • approvers recomputed at apply time, with payload re-validation; • a 14-day expiry, run as a scheduled job that only flips the status; • re-evaluation on an owner's tombstone (§3.4a).
A-22	§3.1 entity, §3.4a, §3.3 roles	Founding owner (R-19 ruling, SECURITY §4.2.2): • `entity.founding_owner_user_id`, NOT NULL, set to the creator, with a trigger that it holds owner; • `app.force_change` and the founder transfer as `poly_govern` definers; • in §3.4a, a successor step for a founder of a multi-owner entity, and a tombstone re-check; • the transfer target becomes founder when a sole-owned entity is transferred.
A-21	§3.3b	The ancestor-invite notice (P5) is a second `poly_graph` trigger: AFTER INSERT on `invitation` (and on `membership` without an invitation) on a parent-kind entity. It walks the descendants and notifies their owners in the same transaction. Not on a role raise.

12.3 Asks on other owners

- **devops-engineer:**
  - §6.2: secrets as files, scoped per container; the keyring goes to `worker` only.
  - §6.6: an asymmetric backup key and an append-only backup store.
  - C-70/C-71: only Caddy publishes ports; the firewall lives in the cloud provider, not on the host.
  - C-75: Postgres logging settings.
  - C-83: a pull-based deploy is preferred.
  - Assert the connection-pooler mode on both targets.
  - *v1.1:* local-box provisioning and its checks (C-76); staging's secrets directory, keyring and Plaid sandbox secret (C-77).

- **ux-designer:** the co-owner approval screens (§4.2.2):
  - a request shown as pending on the members list and the cap table;
  - an approve / decline screen with step-up, showing exactly what changes;
  - the expiry and reminder copy;
  - the requester-confirm prompt after the owner set changes;
  - the invitee sees nothing until apply;
  - a founder marker in the member list;
  - the founder's force screen, shown after a decline or expiry, with step-up and plain copy that every owner, the target included, will be told;
  - the founder transfer and step-down screen;
  - the successor step in the account-deletion flow.
- **qa-engineer:**
  - Every row of §4.2.1 becomes a pgTAP assertion.
  - The battery adds: pool reuse on a dirty backend (C-12); WITH CHECK forgery; catalog coverage plus canary; the definer allowlist; `security_invoker`; TRUNCATE; purge negatives and the zero-rows-remain check (C-50).
  - The log canary (C-33) must land before the first real adapter.
  - *v1.1:* the C-19, C-25 and C-27 tests (graph triggers, roll-up shapes, holder reads), the §4.6 deletion-flow negatives (C-52), and the C-77 config refusals.
- **Principal (via team-lead), 2026-11-07 question set: all ruled.** Q2 was withdrawn after OQ-23. Q1 and Q3 to Q5 are restated as P1, P3, P4 and P6.
  - **P1. Ruled 2026-11-07:** a second factor is required for owners and managers, and optional for viewers. C-03 and R-7 are updated.
  - **P2. Ruled 2026-11-07:** any date range, with honest consent. The inclusion step and the upward-consent notice carry the disclosure (C-25), and the residual is folded into R-17 and approved. There is no period guard in ARCH.
  - **P3. Ruled 2026-11-07:** every pending §11 row is approved. R-1 is re-confirmed on its corrected text. R-3 and R-4 are approved on their updated text.
  - **P4. Ruled 2026-11-07:** the hash chain is built with the ledger in POLY-M2. The weekly verifier and the export head line are in scope (C-24).
  - **P5b. Ruled 2026-11-07:** on a multi-owner entity, every other owner approves invites, role raises, a co-owner's removal or demotion, and cap-table edits (§4.2.2, C-28, T-26). The edges are SecEng rulings in §4.2.2.
  - **R-19. Ruled 2026-11-07:** the target still votes, and a founding owner (the creator) may force a declined or expired co-owner removal, with step-up and a notice to all. The founder

is removable only by stepping down or transferring, and names a successor on account deletion. R-19 now records the hostile-founder risk, approved.

- **P5. Ruled 2026-11-07:** notify, never block. When an invitation to a parent goes live, every owner beneath is notified with the disclosure sentence and the pull-out link (C-25, T-73).
- **P6. Ruled 2026-11-07:** there is no reopen switch. Invitation is the only way in, plus `polycarpic user invite <email>` (C-01, §4.1).
- **P7. Ruled 2026-11-07:** the default is a real domain resolved only on the LAN, with a DNS-01 wildcard (R-18 approved). The supported fallback is `.local` with a name-constrained private CA, OAuth disabled, and email + password + second step (C-76). Plain-http sign-in is refused in both. R-20 was approved 2026-11-07, with the name-constraint check as a gate for the first home-box deploy.
- **P8. Ruled 2026-11-07:** TPM-sealed automatic unlock on the home box (C-72, T-69, R-21).
- **P9. Ruled 2026-11-07:** the home box backs up nightly to an append-only internet storage box. A rotated drive is optional (C-73).

Generated by the `seceng` agent via `/generate-secdoc`. Re-run when ARCH changes; log security decisions in process/DECISIONS.md.